Open Infrastructure Architecture Portfolio

IT Infrastructure, Cloud Architecture, Systems Administration and DevOps Design

Proposed design for an illustrative organization. Nothing has been deployed, tested, or validated.

Source: github.com/amirhosein2015/open-infrastructure-portfolio

Open Infrastructure Architecture Portfolio

IT Infrastructure, Cloud Architecture, Systems Administration & DevOps Design

> **Status: Phases 1–8 complete as drafts. The design is proposed, not implemented.** This is a documentation-first architecture portfolio. Everything described here is a **proposed design** for an **illustrative** organization. Nothing in this repository has been deployed, tested, or validated in a live environment.

---

1. Overview

This repository documents how the IT infrastructure of a small software development company could be designed, secured, documented, and operated. It covers identity, office networking, Microsoft 365, Microsoft Azure, DevOps, and IT operations.

The project is independent. It contains no employer names, branding, or confidential information, and is intended to be reusable across different roles and organizations.

2. Objectives

- Demonstrate systematic infrastructure thinking: requirements, options, trade-offs, decisions.
- Produce documentation that a small IT team could actually maintain.
- Keep the design proportionate to a 15-person organization (no enterprise overengineering).
- Distinguish clearly between baseline controls, optional capabilities, and licence-dependent features.

3. Reference scenario (summary)

An illustrative software development company with **15 employees**, company-managed laptops, one office (wired and wireless), Microsoft 365, Microsoft Entra ID, Microsoft Azure, and Development / Staging / Production environments.

Full scenario and assumptions: `architecture/reference-scenario.md`.

This is **not** a real company's verified infrastructure.

4. Design principles

1. **Proportionality** — design for 15 people with a clear growth path, not for 1,500.
2. **Secure by design** — least privilege, MFA, separated admin accounts, auditability.
3. **Justified choices** — every major technology choice has a recorded reason and alternatives.
4. **No hidden licensing assumptions** — features that depend on a licence tier are labelled as such.
5. **Honest status** — proposed, recommended, conceptual, illustrative, and implemented are never mixed up.
6. **Maintainability** — consistent naming, tagging, ownership, and version-controlled documentation.
7. **Recoverability over backup** — a backup is only proven by a successful restore test.

5. Scope

In scope: architecture documentation, decision records, network and identity design, access model, Azure resource organization, DevOps process design, operations and governance procedures, and editable diagrams.

Out of scope: live deployment, a local lab, executable infrastructure code as a deliverable, application source code, compliance certification, and pricing quotes.

6. Limitations

- No part of the design has been implemented or load-tested.
- IP addresses, VLAN IDs, and names are **examples**.
- RPO/RTO targets are intentionally **not defined**; they must come from business requirements.
- Microsoft licensing and feature availability change; any licensing statement must be re-verified against official Microsoft documentation before use.
- Any code or configuration snippet that appears later is labelled *illustrative, untested*.

7. Architecture domains

#	Domain	Focus
1	Identity and Endpoint Management	Entra ID, MFA, RBAC, lifecycle, laptop security
2	Office Network	Firewall, switching, VLANs, Wi-Fi, DHCP/DNS
3	Microsoft 365 and Collaboration	Exchange Online, Teams, SharePoint, OneDrive, data protection
4	Azure Cloud Infrastructure	Subscription, resource groups, environments, Key Vault, monitoring
5	DevOps and Automation	Git workflow, CI/CD, artifact promotion, IaC concepts (Bicep)
6	IT Operations and Governance	Monitoring, incidents, changes, backup/DR, cost, runbooks

8. Repository structure

```
open-infrastructure-portfolio/
├── README.md
├── architecture/
│   ├── reference-scenario.md
│   ├── overview.md
│   ├── infrastructure-design.md
│   ├── cloud-architecture.md
│   └── network-architecture.md
├── security/
│   ├── identity-management.md
│   ├── access-control-matrix.md
│   └── security-policies.md
├── operations/
│   ├── backup-and-recovery.md
│   ├── monitoring-and-alerting.md
│   ├── onboarding-offboarding.md
│   ├── incident-response.md
│   ├── change-management.md
│   └── governance-and-runbooks.md
├── decisions/
│   ├── architecture-decisions.md
│   └── technology-comparison.md
├── docs/
│   ├── interview-guide.md
│   └── open-infrastructure-portfolio.pdf   # combined read-only copy of the documents
└── diagrams/            # diagrams.net (.drawio) source files + exported images
```

9. Diagrams

Six editable diagrams (diagrams.net) are planned: main architecture, office network, identity and access, Azure resources, DevOps workflow, backup and recovery.

10. Terminology used in this repository

Label	Meaning
Proposed	Part of the design in this portfolio
Recommended	Suggested option; alternatives are documented
Conceptual	Described at design level, no concrete configuration
Illustrative	Example values or snippets; not tested
Implemented	Actually built and verified (currently: none)

Assumption IDs: `A-nn` are defined in `architecture/reference-scenario.md`; `N-nn` in the network architecture, `I-nn` in identity management, `Z-nn` in the cloud architecture, and `D-nn` in the infrastructure design.

11. Project status

Phase	Content	Status
1	Foundation: README, scenario, assumptions, ADRs	Draft
2	Main architecture	Draft
3	Network	Draft
4	Identity and security	Draft
5	Azure	Draft
6	DevOps	Draft
7	IT operations	Draft
8	Final review, interview guide, combined PDF	Draft

12. Licence

To be decided before publication (a documentation licence such as CC BY 4.0 is a common choice).

Reference Scenario and Assumptions

> **Illustrative scenario.** This describes a fictional organization used to ground the architecture. It is not a real company's verified infrastructure.

1. Organization profile

Attribute	Value
Type	Small software development company
Headcount	15 employees
Location	One office; some employees may work remotely occasionally
Devices	Company-managed Windows laptops
Productivity	Microsoft 365
Identity	Microsoft Entra ID
Cloud	Microsoft Azure (primary reference platform)
Environments	Development, Staging, Production
IT staffing	No dedicated large IT team; administration is a part-time or small-team responsibility

2. Illustrative roles

Role	Approx. count (illustrative)
Employee (non-technical)	3
Developer	6
Senior Developer / Team Lead	2
IT Administrator	1
Cloud Administrator	1 (may be combined with IT Administrator)
Management	2

Counts are examples to make the design concrete. Role combinations in a real small company are common and are handled in the access model by assigning *separate accounts* per privilege level.

3. Assumptions

Assumptions are labelled **A-nn** so other documents can reference them.

ID	Assumption	Why it matters
A-01	The organization already holds paid Microsoft 365 and Azure tenants; the portfolio author does not.	Design is realistic; deployment by the author is not required.
A-02	One Microsoft Entra tenant serves both Microsoft 365 and Azure.	Single identity source.
A-03	Specific Microsoft 365 / Entra licence tiers are **unknown**.	Intune, Conditional Access, and similar features are treated as licence-dependent.
A-04	Application technology stack, traffic, and data volumes are **unknown**.	Hosting and database products are deferred (see ADR-004).

ID	Assumption	Why it matters
A-05	No specific regulatory or compliance obligations are assumed.	Controls are a good-practice baseline, not a compliance mapping.
A-06	Business RPO/RTO requirements are **not defined**.	Values are not invented; the process for defining them is documented.
A-07	Internet connectivity is a single business ISP line.	Redundant WAN is listed as a growth option, not a baseline.
A-08	Developers work on company-managed laptops; personal devices are not used for company data in the baseline.	Simplifies endpoint policy.
A-09	The source code is hosted in a managed Git service; the specific provider is a separate decision.	Keeps DevOps documentation vendor-aware but not locked in.
A-10	Budget is limited; costs must be visible and controllable.	Favors managed services and deferring optional capabilities.

4. Explicit non-assumptions

The following are **not** assumed:

- A particular programming language, framework, or database
- Azure Virtual Machines, AKS/Kubernetes, or a dedicated Virtual Network for every workload
- Multiple Azure subscriptions
- A universal VPN requirement
- Conditional Access, Intune, or other premium licence features
- Any compliance framework (ISO 27001, SOC 2, GDPR obligations, etc.)

5. Constraints on the portfolio itself

- Documentation-first: no purchase of cloud, server, or software; no local installation.
- Browser-based, free tooling only (GitHub, diagrams.net, Markdown, PDF).
- No claims of deployment, testing, or production experience.

6. Growth path (preview)

The design should remain valid as the organization grows beyond 15 people. The expected extension points (detailed in later phases) are: additional resource groups or subscriptions when ownership or governance requires it, stronger identity controls when licensing allows, additional network segments, and more automated delivery pipelines.

Architecture Overview

> **Proposed architecture for an illustrative 15-person software company.** Nothing described here has been deployed or tested. See the README for status labels and limitations, and `reference-scenario.md` for assumptions (A-nn) referenced below.

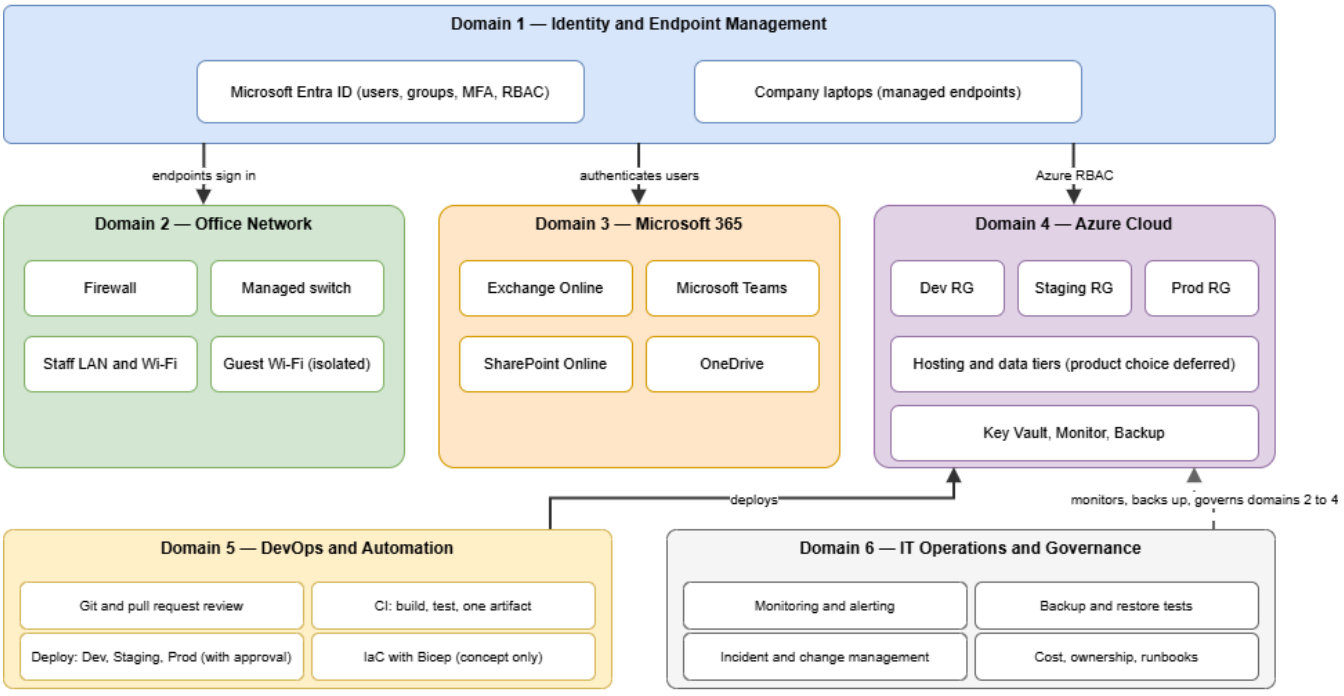
1. Purpose of this document

This document explains how the six architecture domains relate to each other: what depends on what, where trust boundaries sit, and which flows matter. It is intentionally concise. Detailed designs live in the domain documents listed in section 8.

The corresponding diagram is **Diagram 1 — Main Infrastructure Architecture** (`diagrams/01-main-architecture.drawio`).

Diagram 1 — Main Infrastructure Architecture

Proposed architecture for an illustrative 15-person company. Not deployed.



Solid arrows: identity or deployment dependency. Dashed arrow: operational coverage. Staff devices reach Microsoft 365 and Azure over the internet; no VPN in the baseline (ADR-005). RG = resource group.

2. Architecture at a glance

The design has one **identity foundation** (Microsoft Entra ID) that everything else relies on, and three **service planes** that employees and engineers use: the office network, Microsoft 365, and Azure. Two **cross-cutting domains** (DevOps and IT Operations) connect these planes and keep them maintainable.

Layer	Domain	Role in the architecture
Foundation	1. Identity and Endpoint Management	Who a user is, what they may do, and whether their device is trustworthy
Service plane	2. Office Network	Connectivity and local segmentation for staff and guests

Layer	Domain	Role in the architecture
Service plane	3. Microsoft 365 and Collaboration	Email, chat, files, and documents
Service plane	4. Azure Cloud Infrastructure	Hosting for Development, Staging, and Production workloads
Cross-cutting	5. DevOps and Automation	How code and infrastructure changes reach Azure
Cross-cutting	6. IT Operations and Governance	How everything is monitored, backed up, changed, and owned

3. Domain relationships

From	To	Relationship
Identity (1)	Microsoft 365 (3)	Entra ID authenticates users and holds group membership used for licensing and permissions
Identity (1)	Azure (4)	Entra ID is the identity source for the Azure portal and Azure RBAC role assignments
Identity (1)	DevOps (5)	Engineers and pipelines authenticate to Azure through Entra ID identities
Office Network (2)	Internet / cloud services	Staff devices reach Microsoft 365 and Azure endpoints over the internet through the office firewall
Office Network (2)	Identity (1)	Company laptops on the staff network are the managed endpoints that sign in to Entra ID
DevOps (5)	Azure (4)	Pipelines deploy the same build artifact to Development, Staging, and Production
Operations (6)	Azure (4), Microsoft 365 (3), Network (2)	Monitoring, backup, change control, and ownership apply to all three planes
Operations (6)	Identity (1)	Access reviews, onboarding, and offboarding are operational processes executed against Entra ID

Key point: the office network is *not* the gateway to Azure or Microsoft 365. Both are cloud services reached over the internet and protected by identity and access controls. This is why VPN is not part of the baseline (see ADR-005). It would be added only if resources require private network connectivity.

4. Trust boundaries

Boundary	Separates	Primary control
Internet edge	Office network from the public internet	Firewall rules (default deny inbound)
Guest / staff	Visitor devices from company resources	Separate network segment with firewall restrictions (detailed in Phase 3)
Identity boundary	Authenticated users from everyone else	Entra ID sign-in and MFA
Privilege boundary	Ordinary accounts from administrative accounts	Separate admin accounts, least-privilege RBAC
Environment boundary	Development / Staging / Production	Azure RBAC and resource-group scoping (logical separation — see ADR-002)

In this design, **identity is the primary security perimeter** for cloud resources. Network controls protect the office; they do not protect Azure or Microsoft 365 data.

5. Key flows

5.1 Employee sign-in and access. An employee signs in to a company laptop and to Microsoft 365 or the Azure portal with an Entra ID account. MFA is part of the baseline; which enforcement mechanisms are available depends on licensing (A-03, ADR-003). Group membership determines access.

5.2 Change delivery. A developer changes code in Git, opens a pull request, a reviewer approves it, and the pipeline builds one artifact. That same artifact is deployed to Development, validated in Staging, and promoted to Production after an explicit approval. Detail in Phase 6.

5.3 Operations loop. Monitoring and logging detect problems; incidents and changes are handled through documented processes; backups are verified by restore tests. Detail in Phase 7.

6. Design trade-offs at the overview level

Decision	Chosen	Alternative	Trade-off
Where the security perimeter sits	Identity-centric (Entra ID) with office firewall for local network	Network-centric (VPN into a private network for everything)	Identity-centric is simpler and cheaper and fits cloud services reached over the internet, but it depends heavily on correct identity configuration and MFA. Network-centric adds private connectivity but also cost and operational burden (ADR-005).
Number of Azure subscriptions	One, with resource groups per environment	One per environment	Lower overhead versus stronger isolation (ADR-002).
Application hosting	Deferred; shown as a generic "hosting tier"	Pick a specific service now	Avoids guesswork versus a less concrete diagram (ADR-004).
Licence-dependent controls	Optional enhancements over a baseline	Design around premium features	Honest and affordable baseline versus possibly weaker controls until upgraded (ADR-003).

7. Assumptions and limits specific to this overview

- Labels in Diagram 1 are generic on purpose (for example "Hosting tier", "Data tier") because the application stack is unknown (A-04).
- The diagram shows logical relationships, not network paths or sizing.
- No RPO/RTO values appear anywhere; they must come from business requirements (A-06).

8. Where the details live

Topic	Document	Phase
Office network, VLANs, Wi-Fi	`network-architecture.md`	3
Entra ID, MFA, access matrix	`security/identity-management.md`, `security/access-control-matrix.md`	4
Azure resources	`cloud-architecture.md`	5
CI/CD and IaC concepts	DevOps sections of `infrastructure-design.md`	6
Monitoring, backup, incidents, changes	`operations/*.md`	7
Decisions and rationale	`decisions/architecture-decisions.md`	1 onward

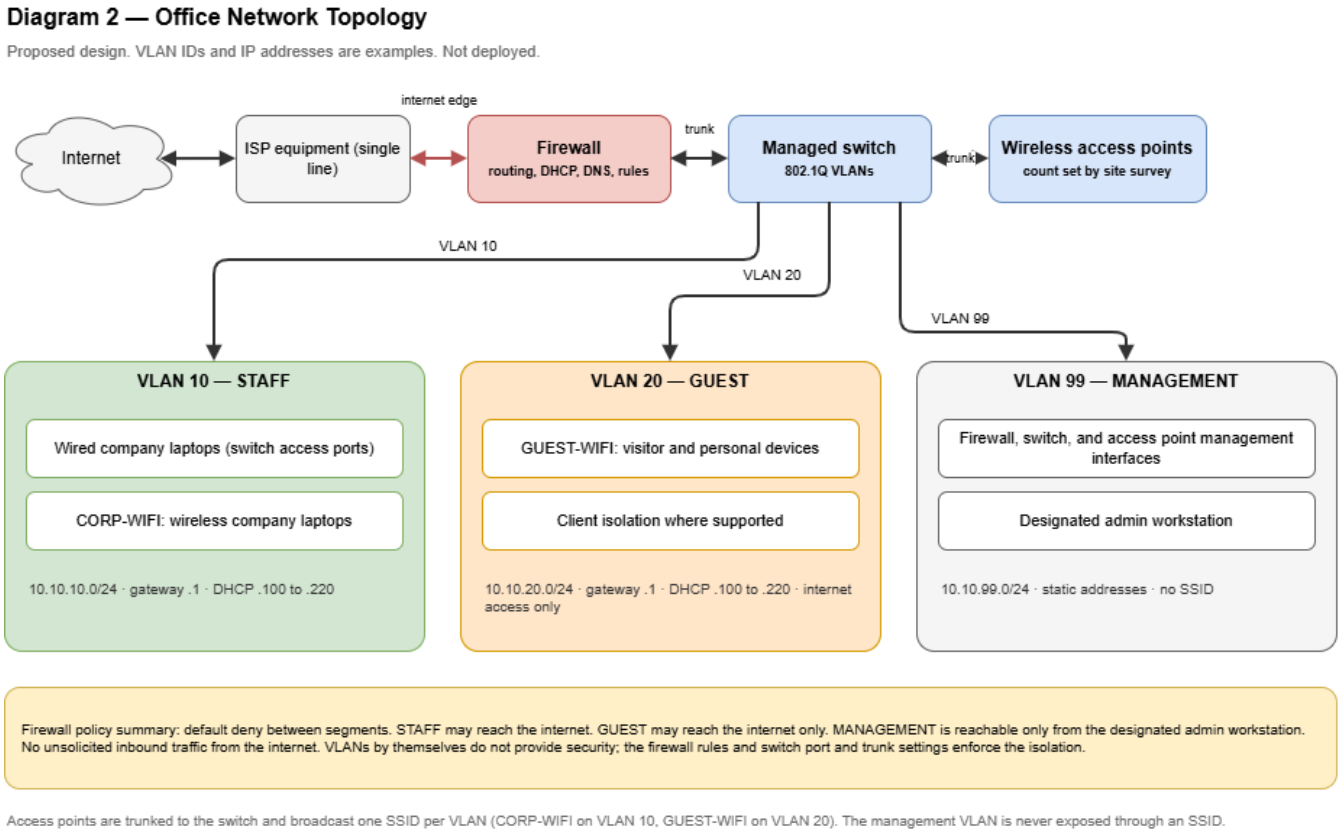
9. Well-Architected review note

The five Azure Well-Architected pillars (Reliability, Security, Cost Optimization, Operational Excellence, Performance Efficiency) will be used as a practical checklist in Phase 8. This is a self-review aid, not an official Microsoft assessment, and no assessment has been performed.

Network Architecture

> **Proposed, illustrative design.** All VLAN IDs, IP addresses, SSID names, lease times, and device counts below are **examples**. Nothing has been configured or tested. Assumption IDs (A-nn) refer to `reference-scenario.md`; decisions are recorded in `../decisions/architecture-decisions.md` (ADR-008, ADR-009).

Diagram: **Diagram 2 — Office Network Topology** (`diagrams/02-office-network-topology.drawio`).



1. Purpose and scope

This document describes the logical network of a single office for about 15 employees: how devices connect, how traffic is segmented, and which controls protect each segment.

In scope: internet connection, firewall, managed switch, wired and wireless access, VLAN and IP plan, DHCP, DNS, high-level firewall policy, guest isolation, remote access position, and network monitoring.

Out of scope: cloud networking in Azure (Phase 5), IPv6, vendor/model selection, cabling and floor plans, and physical site survey.

2. Network-specific assumptions

ID	Assumption	Consequence
N-01	One office, one floor, one internet line (consistent with A-07)	No site-to-site links; no redundant WAN in the baseline

ID	Assumption	Consequence
N-02	No on-premises servers; business applications live in Microsoft 365 or Azure	No server VLAN in the baseline; no on-premises directory service
N-03	The firewall, managed switch, and access points support 802.1Q VLANs and a stateful firewall policy	Hardware class is stated, not a specific product
N-04	Staff use company-managed laptops (A-08); personal phones may use Wi-Fi	Personal devices are placed on the guest segment unless policy says otherwise
N-05	IPv4 only is documented	IPv6 is a documented gap, not a design decision

3. Components

Component	Role	Notes
ISP connection	Internet access	Single line (A-07). Equipment supplied by the ISP is treated as an untrusted upstream boundary.
Firewall	Internet edge, inter-VLAN routing and policy, DHCP, DNS forwarder	Single enforcement point for all inter-segment traffic (ADR-008)
Managed switch	Layer 2 switching, VLAN tagging, wired access ports, PoE for access points if available	Access ports for wired staff devices; trunk ports to the firewall and access points
Wireless access points	Staff and guest Wi-Fi	Quantity depends on a site survey; two is an illustrative figure
Admin workstation	Management of network devices	Reaches the management segment only through a designated path (see section 7)

4. VLAN and IP addressing plan (illustrative)

Private IPv4 ranges are taken from the blocks reserved for private networks in RFC 1918 (`10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`). No public IP addresses are used or invented in this document.

VLAN ID	Name	Purpose	Subnet	Gateway	DHCP range	Status
10	STAFF	Company laptops and staff devices (wired and Wi-Fi)	10.10.10.0/24	10.10.10.1	10.10.10.100 – 10.10.10.220	Baseline
20	GUEST	Visitor and personal devices, internet only	10.10.20.0/24	10.10.20.1	10.10.20.100 – 10.10.20.220	Baseline
99	MGMT	Management interfaces of firewall, switch, and access points	10.10.99.0/24	10.10.99.1	None (static addresses)	Baseline
30	SHARED	Shared devices such as a printer, only if required	10.10.30.0/24	10.10.30.1	10.10.30.100 – 10.10.30.150	Optional, not deployed in baseline

Design notes:

- **Sizing:** a /24 provides far more addresses than 15 employees with several devices each need. The reason for /24 is simplicity and growth headroom, not capacity pressure.
- **Static addresses (MGMT):** gateway `10.10.99.1`, switch `10.10.99.2`, access points `10.10.99.11` and up. Below `.100` in STAFF and GUEST remains free for static reservations.
- **Default VLAN:** avoid carrying user or management traffic on the switch's default VLAN 1. (Own recommendation.)
- **Lease times (illustrative):** staff devices one day, guest devices one hour, so guest addresses recycle quickly.

- **Gateway concept:** the firewall owns the `.1` address of every VLAN and routes between them. Hosts reach other segments or the internet only through it.
- **Documentation hygiene:** keep this table as the single source of truth and update it with every network change (see change management, Phase 7).

5. DHCP and DNS

Service	Design	Reason
DHCP	Provided by the firewall, one scope per VLAN (MGMT uses static addresses)	No on-premises servers (N-02); one device to manage
DNS for clients	Clients receive the VLAN gateway as DNS server; the firewall forwards queries to upstream resolvers	Central place to change resolvers; no internal DNS zone needed
Internal names	None required	Applications are cloud-hosted (N-02)

Trade-off — upstream DNS resolver

Option	Advantage	Disadvantage
ISP resolver	Zero configuration	Less control and visibility; behavior depends on the ISP
Public recursive resolver	Easy, consistent, independent of ISP	Third-party dependency; queries leave the organization
Filtering/security DNS service	Can block known malicious domains	May involve cost or licensing; must be verified before adoption

Baseline: a public recursive resolver or the ISP resolver, chosen by the organization. A filtering service is an optional enhancement and no pricing or feature claims are made here.

Trade-off — where DHCP/DNS runs

Option	Advantage	Disadvantage
On the firewall (chosen)	Simple; no extra server	Firewall outage also stops address assignment
On a separate server	Richer features	Needs a server to run and patch, which N-02 excludes

6. Wi-Fi design

SSID (example)	VLAN	Audience	Access
CORP-WIFI	10	Company-managed devices	Staff segment
GUEST-WIFI	20	Visitors and personal devices	Internet only

The management VLAN is never exposed through an SSID.

Staff Wi-Fi authentication — trade-off

Option	Advantage	Disadvantage
A. Shared passphrase (WPA3-Personal, or WPA2/WPA3 transition mode for older clients)	Simple; no extra infrastructure	Everyone shares one secret; it must be changed when someone with knowledge leaves; no per-user identity in logs
B. 802.1X with a RADIUS server (WPA2/WPA3-Enterprise)	Per-user or per-device credentials; revocation follows the account	Needs a RADIUS service and credential/certificate design; integration with the organization's identity platform must be verified, not assumed

Decision (ADR-009): option A as the baseline for 15 people, with a documented rotation rule at offboarding, and option B as the upgrade path.

Guest Wi-Fi controls:

- Separate SSID, VLAN 20, and separate passphrase, rotated periodically.
- Client isolation enabled so guest devices cannot talk to each other (if the access points support it).
- Firewall policy allows internet access only (section 7).
- Optional: bandwidth limits and a splash page; neither is required for security.

What the Wi-Fi Alliance states about WPA3 (see sources): WPA3-Personal uses Simultaneous Authentication of Equals to make password guessing harder, WPA3 networks require Protected Management Frames, and WPA3-Enterprise offers stronger cryptography for sensitive environments. Open-network protection is a separate Wi-Fi Alliance program (Enhanced Open). Whether the chosen access points and every client support these modes must be verified per device.

7. Firewall policy (high level)

Principle: between zones the default is **deny**; each allowed flow is stated explicitly. A VLAN separates Layer 2 broadcast domains, but **VLANs alone do not provide security**. Isolation exists only if the Layer 3 gateway's rules, switch port configuration, and trunk settings enforce it. A misconfigured trunk or access port can defeat segmentation.

#	From	To	Action	Notes
1	STAFF	Internet	Allow	Optional egress filtering later
2	STAFF	GUEST	Deny	
3	STAFF	MGMT	Deny, except designated admin host(s)	Management protocols must be encrypted; unencrypted ones disabled
4	GUEST	Internet	Allow	Web and standard services; no inbound
5	GUEST	STAFF, MGMT, SHARED	Deny	Core guest isolation rule
6	GUEST	Gateway	Allow DHCP and DNS only	No access to firewall management
7	MGMT	Internet	Allow only what updates and time sync need	Keep the list short
8	MGMT	STAFF, GUEST	Deny	
9	Internet	Any internal	Deny unsolicited inbound	No port forwarding in the baseline; public applications run in Azure
10	Any	Any	Log denied inter-zone traffic and administrative logins	Review on a schedule (Phase 7)

Management of network devices: administration only from the MGMT segment, never from the internet side; vendor default credentials changed; unencrypted management protocols disabled; firmware kept current; configuration backed up securely. These practices follow CISA's guidance on securing network infrastructure devices.

Trade-off — where inter-VLAN routing happens

Option	Advantage	Disadvantage
Firewall routes between VLANs (chosen)	One policy point; simplest to audit	All inter-VLAN traffic crosses the firewall (not a concern at this size)
Layer 3 switch routes between VLANs	Faster internal routing	Policy split across two devices; more to configure and verify

8. Remote access

Baseline: no VPN. Employees away from the office reach Microsoft 365 and Azure over the internet, protected by identity controls (Phase 4). This follows ADR-005.

Private connectivity would be added only if a resource requires it, for example an internal-only service or private administrative access. At that point the options and their trade-offs would be documented in a new ADR.

Remote administration of the office network itself is **not enabled** in the baseline. If it becomes necessary, the choice among a vendor's cloud management service, a VPN into the management segment, and a hardened admin host is a separate decision with its own risk assessment.

9. Network monitoring

Area	Baseline practice
Availability	Regular checks that the internet link, firewall, switch, and access points are reachable
Logs	Firewall and device logs retained for a defined period and reviewed on a schedule
Time	Consistent time source on all devices so logs correlate
Configuration	Backups of firewall, switch, and access point configurations, stored securely
Firmware	Tracked versions and a patching routine

Trade-off — monitoring approach

Option	Advantage	Disadvantage
Built-in device dashboards	No extra tools	Per-device view; weak history and alerting
Dedicated monitoring tool	Central view and alerts	Needs hosting and maintenance, which conflicts with N-02
Cloud-managed vendor service	Central view without on-premises hosting	Depends on the vendor; licensing must be verified

The decision is documented in `../operations/monitoring-and-alerting.md`, section 8 (ADR-020): built-in device dashboards as the baseline, a cloud-managed vendor service as an optional enhancement, and no self-hosted tool. Retention periods and alert thresholds are not defined here.

10. Availability and risk

- **Single points of failure:** one ISP line, one firewall, one switch. An outage stops office connectivity.
- **Impact:** cloud services keep running, but staff in the office lose access to them until connectivity returns. A phone hotspot is a practical stopgap.
- **Not defined:** recovery objectives. RTO and RPO must come from business requirements (A-06).
- **Mitigation options when justified:** second ISP with failover, firewall high availability, spare hardware, documented restore of device configurations.

11. Growth path

Trigger	Extension
More staff or devices	More access points, larger or additional subnets
Frequent staff turnover or compliance need	802.1X authentication (ADR-009 option B)
Printers or shared devices	Enable the optional SHARED VLAN

Trigger	Extension
Business dependence on connectivity	Second ISP and failover, firewall high availability
Multiple offices	Site-to-site connectivity, an address plan that avoids overlaps across sites

Planning ahead: choose non-overlapping ranges before adding sites or any private connection to Azure.

12. Limitations

- The plan has not been configured or tested on any device.
- Vendor features, performance, and licensing are not assessed.
- IPv6, cabling, power, and physical security of the network closet are not covered.
- Wi-Fi coverage and access point count require a site survey.

13. Well-Architected quick check (self-review, not an official assessment)

Pillar	Observation
Security	Segmentation with explicit deny rules, guest isolation, restricted management plane
Reliability	Single points of failure are acknowledged; no objectives invented
Cost Optimization	Firewall-based DHCP/DNS and no server avoid extra cost; optional items are deferred
Operational Excellence	One authoritative IP plan; logging, backups, and review routines named
Performance Efficiency	Sized for 15 users; no performance claims made

14. Sources

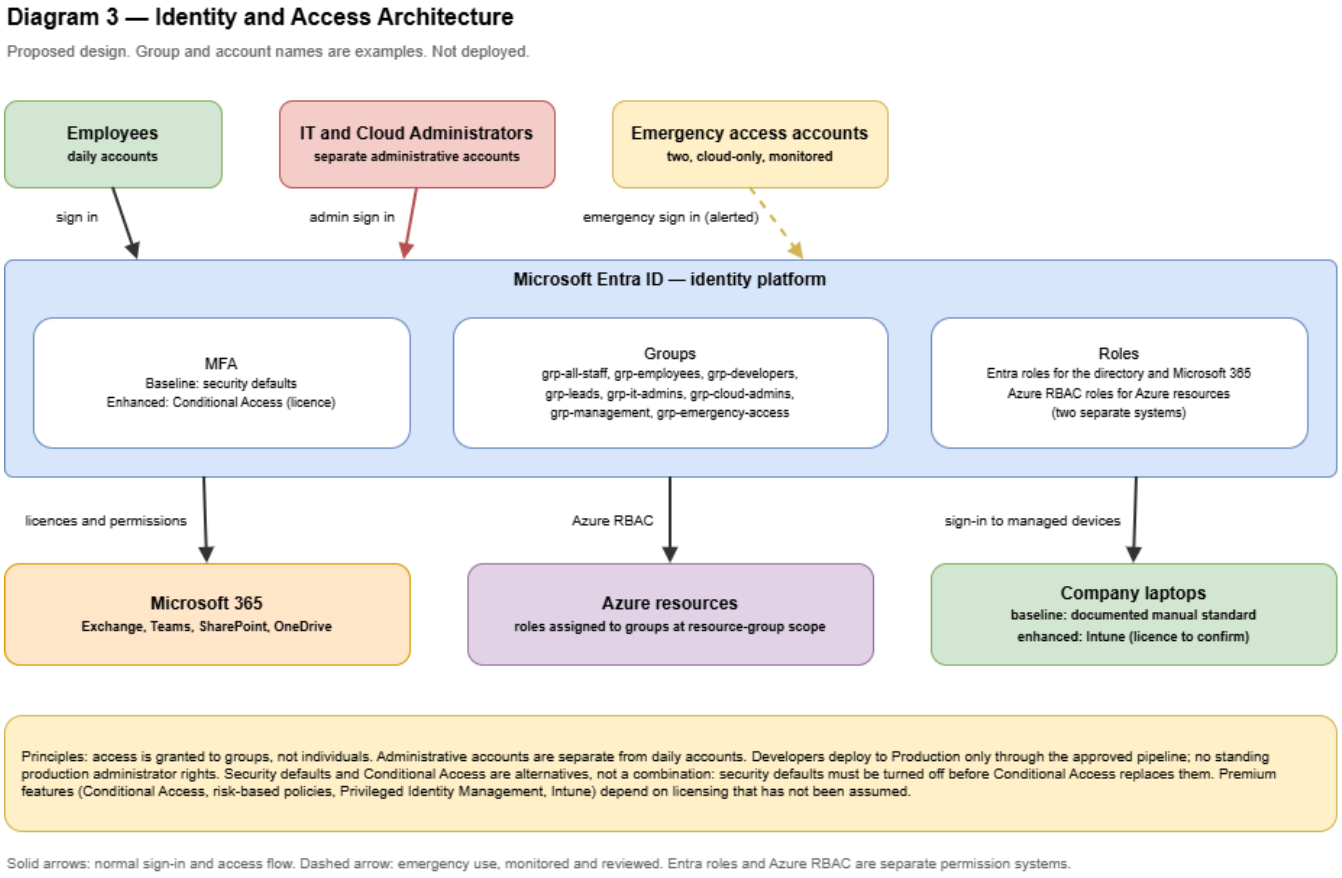
Accessed 2026-11-13. These are the official documents behind the claims marked above; design choices and recommendations are the author's own.

Topic	Source
Private IPv4 address blocks	RFC 1918 — Address Allocation for Private Internets
WPA3-Personal, WPA3-Enterprise, Protected Management Frames, Enhanced Open	Wi-Fi Alliance — Wi-Fi CERTIFIED WPA3 announcement
Securing network infrastructure devices, segmentation, management access, logging	CISA — Securing Network Infrastructure Devices (ST18-001)

Identity Management

> **Proposed, illustrative design.** Nothing here has been configured or tested. Assumption IDs (A-nn) refer to `../architecture/reference-scenario.md`; decisions are in `../decisions/architecture-decisions.md` (ADR-010 to ADR-012). Licensing statements are taken from official Microsoft documentation, **accessed 2026-11-13**, and must be re-verified before use (see section 12).

Diagram: **Diagram 3 — Identity and Access Architecture** (`diagrams/03-identity-and-access.drawio`).



1. Purpose and scope

This document describes how people and devices are identified, authenticated, and authorized in the reference organization, and how company laptops are secured.

In scope: Microsoft Entra ID as the identity platform, groups, MFA, administrative accounts, emergency access, password and authentication policy, role-based access, endpoint security, and licensing dependencies.

Out of scope: Azure resource design (Phase 5), the detailed lifecycle procedures (see `../operations/onboarding-offboarding.md`), pricing, and product-specific click-paths.

Platform distinction: Microsoft Entra ID is the **identity platform**. Microsoft 365 is the **productivity and collaboration platform** that uses it. Azure RBAC grants access to Azure resources, while Entra roles grant administrative rights over the directory and Microsoft 365 services. These are different permission systems.

2. Identity-specific assumptions

ID	Assumption	Consequence
I-01	One Entra tenant serves Microsoft 365 and Azure (A-02)	One place for joiners, movers, and leavers
I-02	Users are cloud-only identities; there is no on-premises Active Directory (consistent with N-02)	No directory synchronization design
I-03	The licence tier is unknown (A-03)	Two documented paths: a baseline that works without premium licences and an enhanced path
I-04	Role holders are named people in the illustrative counts of the reference scenario	Role combinations are handled with separate accounts, not shared accounts
I-05	Staff use company-managed Windows laptops (A-08)	Endpoint controls target Windows

3. Identity model

Object	Design
User accounts	One named account per person, cloud-only, in the organization's tenant
Administrative accounts	A **separate** account for each person who administers (for example `adm-` prefix, illustrative). It is used only for administration, has no mailbox-based daily work, and holds only the roles needed
Emergency access accounts	Two cloud-only accounts, see section 6
Groups	Access is granted to **groups, never directly to individuals** (see section 4)
Guests	Not part of the baseline. If external collaborators are needed, they are added as guest users with limited access and reviewed
Service identities	Pipelines and applications use managed identities or service principals (Phase 5 and 6), not personal accounts

4. Groups and role-based access

Groups mirror the roles in the reference scenario. Membership is the control point for licences, Microsoft 365 permissions, and Azure role assignments.

Group (illustrative name)	Members	Purpose
`grp-all-staff`	Everyone	Baseline Microsoft 365 access and policies
`grp-employees`	Non-technical staff	Role-based access
`grp-developers`	Developers	Development environment access
`grp-leads`	Senior developers and team leads	Staging access and production approval
`grp-it-admins`	IT administrator accounts	Administrative roles over identity, devices, and Microsoft 365
`grp-cloud-admins`	Cloud administrator accounts	Azure administrative roles
`grp-management`	Management	Read-only access to reports and monitoring
`grp-emergency-access`	The two emergency accounts	Exclusion from blocking policies

The detailed permissions per role are in [`access-control-matrix.md`](access-control-matrix.md).

Trade-off — group-based versus direct assignment

Option	Advantage	Disadvantage
Group-based (chosen)	Access changes follow role changes; easy to review and to offboard	Needs a clear naming and ownership convention
Direct assignment	Quick for a single exception	Becomes unreviewable; permissions linger after people move

Group-based assignment is also how Azure RBAC is intended to be used: a role assignment consists of a security principal, a role definition, and a scope, and a group can be the principal.

5. Multi-factor authentication

MFA is part of the baseline. How it is **enforced** depends on licensing.

Path	Mechanism	Licence	What Microsoft documents
Baseline	Security defaults	None; available at no extra cost	MFA registration for all users, MFA for administrators at every sign-in, MFA for privileged activities such as the Azure portal, blocking of legacy authentication, and blocking device code flow. Settings are on or off only, with no customization
Enhanced	Conditional Access policies	At least Microsoft Entra ID P1. Microsoft states that Microsoft 365 Business Premium also provides Conditional Access	Fully customizable policies. Security defaults must be turned off first
Advanced	Risk-based policies (Entra ID Protection)	Microsoft Entra ID P2	Policies that react to sign-in or user risk

Trade-off — security defaults versus Conditional Access

Option	Advantage	Disadvantage
Security defaults	Free, quick, a sound starting point for small organizations with no premium licence	No exceptions or tuning; one setting for everyone; cannot be combined with Conditional Access
Conditional Access	Precise control (by group, application, device state, location) and exclusions such as emergency accounts	Requires licensing and careful design; a policy mistake can lock out administrators

Decision (ADR-010): Security defaults are the baseline and Conditional Access is the documented enhancement, chosen once licensing is confirmed. They are alternatives, not a combination, because Microsoft states that security defaults must be disabled before Conditional Access policies replace them.

Authentication method guidance:

- Prefer an authenticator app with number matching over SMS or voice. The security defaults documentation describes the number-entry prompt as helping to prevent MFA fatigue attacks. (Own recommendation beyond that statement: phishing-resistant methods such as passkeys should be adopted where supported.)
- Do not disable authentication methods that security defaults rely on. Microsoft warns that doing so can lock an administrator out of the tenant.
- Confirm that no legacy protocols are in use before enabling, because security defaults block them.

6. Administrative accounts and emergency access

Principles:

1. **Separation:** administrators use a daily account for email and browsing and a separate administrative account for administration.
2. **Least privilege:** each administrative account receives only the roles its holder needs, preferably the narrowest role that fits rather than a broad one.
3. **Few global administrators:** the highest-privilege role is limited to a very small number of accounts.
4. **No shared accounts:** every administrative action must be attributable to a person.
5. **Periodic review:** administrative role membership is reviewed on a schedule (section 9).

Emergency access ("break-glass") accounts. Microsoft's guidance, paraphrased:

Topic	Recommendation
Number	Two or more, so one remains usable if the other is unavailable
Type	Cloud-only, on the `.onmicrosoft.com` domain, not federated or synchronized
Authentication	A phishing-resistant, passwordless method (Microsoft recommends passkeys) that differs from the method normal administrators use and does not depend on devices or services that could fail in an emergency
Policies	Excluded from Conditional Access policies that block or restrict sign-in, for example through a dedicated group; tested regularly
Monitoring	Send sign-in logs to Azure Monitor and alert on any sign-in by these accounts at critical severity
Storage	Credentials known only to authorized individuals, stored securely in separate locations, not tied to any individual or personal device
Validation	At least every 90 days and after IT staffing or subscription changes

Note on the baseline path: security defaults have no exclusion mechanism, so emergency access accounts are still subject to security defaults. The credential design must therefore satisfy the MFA requirement. This must be verified before the accounts are relied upon.

Privileged Identity Management (time-limited, approved elevation of roles) requires **Microsoft Entra ID P2 or Entra ID Governance**. It is an optional enhancement and not part of the baseline. Without it, administrative roles are assigned permanently to separate administrative accounts, which makes the review cadence and the separation of accounts more important.

7. Password and authentication policy

Area	Baseline
Passwords	Long passphrases preferred over complexity rules; no periodic forced rotation without evidence of compromise; blocking of known-weak passwords where the platform provides it
Password manager	Employees use an approved password manager for passwords outside Entra. Azure Key Vault is for **application** secrets, keys, and certificates and is **not** a store for employee passwords
Self-service password reset	Enable it only after the authentication methods are verified for the licence in use
Account lockout and sign-in logging	Retain sign-in logs and review unusual activity (Phase 7)
Legacy authentication	Blocked (security defaults do this; with Conditional Access a policy must do it)

The password guidance is the author's recommendation and is not attributed to a specific Microsoft statement. The exact policy values should be confirmed against current Microsoft and national guidance when the design is applied.

8. Endpoint and device security

Company-managed Windows laptops (A-08, I-05). The controls are listed as baseline or licence-dependent so no dependency is hidden.

Control	Baseline (no extra licence assumed)	Enhanced (licence or tooling dependent)
Disk encryption	BitLocker enabled on every laptop; recovery keys stored in a controlled, documented location	Central enforcement and escrow through device management
Operating system updates	Windows Update enabled with a documented patching routine	Managed update rings through device management
Endpoint protection	Built-in Windows antimalware kept enabled and updated	Centrally managed endpoint protection and reporting
Local accounts	Employees do not use local administrator rights for daily work; administrator rights only for the IT administrator	Enforced by policy through device management
Device inventory	A maintained inventory with owner, serial number, and status	Automatic inventory through device management
Lost or stolen device	Documented procedure: revoke sessions, disable the account if needed, report	Remote lock or wipe through device management
Compliance-based access	Not available	Conditional Access conditions on device compliance (needs Conditional Access and device management)

Licensing note — Microsoft Intune. Microsoft's Intune licensing page states that Intune is included only with the licences listed on its plans and pricing page, and names Microsoft 365 E3, E5, and E7 as examples of bundles that include it. That page does **not** name Microsoft 365 Business Premium, so this document makes **no claim** about whether Business Premium includes Intune. The organization must confirm the position against the current plans and pricing page.

Trade-off — device management

Option	Advantage	Disadvantage
Manual baseline (documented procedures)	No extra licence or tooling	Depends on discipline; no central proof of compliance; scales poorly
Intune-based management (when licensed)	Central enforcement, reporting, compliant-device conditions	Licence cost; configuration and operation effort

Decision (ADR-011): a documented manual baseline now, with Intune-based management as the upgrade when licensing is confirmed.

9. Access reviews

Review	Frequency (illustrative)	Reviewer	Content
Administrative role membership	Quarterly	Management with the IT administrator	Who holds which role and why
Group membership	Quarterly and at every role change	Group owners	Remove members who changed role
Emergency access accounts	At least every 90 days	IT administrator	Sign-in test, credential custody, documentation
Guest accounts (if any)	Quarterly	Sponsor	Remove unneeded guests
Azure role assignments	Quarterly	Cloud administrator	Review at subscription and resource-group scope

Frequencies are illustrative. Automated access review tooling is a licence-dependent enhancement and is not assumed.

10. Auditability

- Sign-in and audit logs are retained and reviewed as described in the operations phase. Retention periods are not defined here.
- Administrative actions are attributable to named administrative accounts.
- Any use of an emergency account triggers an alert and a documented review.

11. Growth path

Trigger	Extension
Premium licence acquired	Replace security defaults with Conditional Access; add device-compliance conditions
Rising privileged activity	Privileged Identity Management for time-limited elevation
Growing headcount	Automated joiner and leaver workflows; access review tooling
Customer or regulatory demand	Mapping to a compliance framework (not assumed today)
On-premises systems appear	Revisit I-02 and design directory synchronization

12. Limitations and verification

- No tenant has been configured. All behavior is described from documentation.
- Licence and feature availability change. Every statement tagged with a licence in this document must be re-verified against current Microsoft documentation before use.
- Not verified here: BitLocker edition and management requirements, self-service password reset by licence, and Intune inclusion in Microsoft 365 Business Premium.
- Role names, group names, and prefixes are examples.

13. Well-Architected quick check (self-review, not an official assessment)

Pillar	Observation
Security	MFA baseline, separated administrative accounts, emergency access, group-based least privilege
Reliability	Emergency access protects against administrator lockout; no recovery objectives invented
Cost Optimization	Free baseline path; paid capabilities deferred and labelled
Operational Excellence	Defined reviews, naming, and ownership; lifecycle in a separate document
Performance Efficiency	Not materially applicable to identity at this scale

14. Sources

Accessed 2026-11-13. Design choices and recommendations beyond these statements are the author's own.

Topic	Source
Security defaults: what they enforce, cost, limitations, relation to Conditional Access	Microsoft Learn — Security defaults in Microsoft Entra ID
Licence tiers for Conditional Access, risk-based policies, PIM; Business Premium and Conditional Access	Microsoft Learn — Microsoft Entra licensing
Emergency access accounts	Microsoft Learn — Manage emergency access admin accounts
Azure RBAC model: scopes, role assignments, groups, additive permissions, no extra cost	Microsoft Learn — What is Azure RBAC?

Topic	Source
Intune licensing	Microsoft Learn — Microsoft Intune licensing

Access Control Matrix

> **Proposed model, not an actual company's access configuration.** Roles, counts, and permissions are illustrative and apply to the fictional 15-person organization in `../architecture/reference-scenario.md`. Nothing has been configured or tested.

1. Principles

1. **Least privilege:** each role receives the minimum access needed. Production is the most restricted.
2. **Groups, not individuals:** access is granted to groups (`identity-management.md`, section 4).
3. **Separate accounts:** anyone holding an administrative role uses a **separate administrative account**. The daily account holds no administrative rights.
4. **No standing production administration for developers:** developers do not receive administrator access to Production.
5. **Scope narrowly:** Azure roles are assigned at **resource-group scope**, not subscription scope, except for the very few accounts that must manage the subscription (ADR-002). Azure RBAC is additive, so a broad assignment at a higher scope overrides a narrow one beneath it.
6. **Review regularly** (identity-management section 9).

2. Legend

Code	Meaning
—	No access
R	Read only (view)
U	Use as an ordinary user
C	Contribute: create and change resources or content, but not manage access
D	Deploy through the pipeline only; no direct changes to resources
A	Approve (for example, a production release)
Admin	Administrative control of that area
Own	Access to own data only

3. Matrix

Area	Employee	Developer	Senior Developer / Team Lead	IT Administrator	Cloud Administrator	Management
Microsoft 365 (mail, Teams, files)	U	U	U	U (daily account); Admin (administrative account, M365 and Entra scope)	U	U
Office network (staff Wi-Fi/LAN)	U	U	U	U; Admin of network devices from the management VLAN	U	U
Office network (management VLAN)	—	—	—	Admin	—	—

Area	Employee	Developer	Senior Developer / Team Lead	IT Administrator	Cloud Administrator	Management
Development environment	—	C	C	R	Admin	—
Staging environment	—	D	C and A	R	Admin	—
Production environment	—	R (limited, for diagnosis)	D (through the approved pipeline) and A	R	Admin	—
Azure Portal	—	R or C (Development resource group only)	C (Development and Staging resource groups)	R	Admin	R (cost and overview only)
Monitoring (dashboards, logs, alerts)	—	R (Development and Staging)	R (all environments)	Admin	Admin	R (summary dashboards)
Backup management (configure, restore)	—	—	—	Admin (Microsoft 365 data and device configurations)	Admin (Azure workloads)	—

Notes:

- **Production access for developers:** Developers and leads change Production **only through the pipeline**, after review and approval. Direct changes and standing administrator rights are not granted. Read access for diagnosis should be limited and logged. Break-glass elevation for incidents is a documented exception (see section 4).
- **Cloud Administrator and IT Administrator:** in the illustrative counts these may be the same person. That person still uses a **daily account** for ordinary work and a **separate administrative account** for administration, never one account for both.
- **Management:** read-only views for oversight; no technical changes.
- **Backup:** restore operations are administrative and require a documented request. Who can restore which data, and the restore-test cadence, are defined in Phase 7.
- **Employee** access to Azure is none; the role uses Microsoft 365 and the office network only.

4. Exceptions and elevation

Situation	Handling
Urgent production issue needing more access than normal	A cloud administrator performs the action, or grants time-limited access that is removed afterwards. The reason and the time are recorded. Time-limited, approval-based elevation through Privileged Identity Management requires Microsoft Entra ID P2 or Entra ID Governance and is **not assumed** in the baseline
Temporary project access	Time-limited group membership with an owner and an end date
Lost administrator	Emergency access accounts (identity-management section 6)

5. Azure role mapping (illustrative)

Built-in Azure roles are used where they fit. Microsoft's documentation shows that built-in roles range from high-level to specific and that custom roles are possible when none fits. The mapping below uses common built-in role names and must be verified against the permissions of each role before use.

Group	Development RG	Staging RG	Production RG	Subscription scope
`grp-developers`	Contributor	Reader	Reader (limited)	—
`grp-leads`	Contributor	Contributor	Reader	—
`grp-cloud-admins`	Contributor	Contributor	Contributor	Owner for the separate administrative accounts only (at most two; ADR-014)
`grp-it-admins`	Reader	Reader	Reader	—
`grp-management`	—	—	—	Reader (cost and overview only)

Resolved in Phase 5 (see ADR-014):

- **Owner role:** the cloud administrator's separate administrative account holds Owner at subscription scope (with at most one deputy) so it can create resource groups and manage role assignments. The group-based assignments at resource-group scope are Contributor. A narrower role that replaces Owner is to be evaluated and verified, not assumed.
- **Pipeline identity:** a managed identity or service principal scoped to the target resource group (detail in Phase 6).
- **Developer Contributor on Development:** kept for the Development resource group only, subject to the quarterly review. Staging is read-only for developers and Production is read-only with logged access.

6. Limitations

- The matrix is a model. Real access depends on licences, product permissions, and application design.
- Role and group names are examples.
- No access has been implemented or tested.

Security Policies

> **Proposed, illustrative policy set.** These are example policies for a fictional 15-person organization, written to be adoptable and reviewable. They are not the policies of a real company and have not been applied. Licence-dependent items are labelled. See `identity-management.md` for the supporting design and sources.

1. Purpose and how to read this document

This document turns the architecture into short, checkable rules. Each policy has an **owner**, a **baseline requirement**, and, where relevant, an **optional enhancement** that depends on licensing or additional tooling.

Label	Meaning
Baseline	Expected in the reference design with no premium licence assumed
Enhanced	Needs a licence or tooling that must be confirmed first
Owner	The role accountable for keeping the policy true

Terms such as "must" and "should" are used in their ordinary sense: **must** is required by this policy, **should** is a strong recommendation.

2. Policy summary

#	Policy	Baseline	Enhanced	Owner
P-01	Least privilege and access control	Group-based access; access matrix applied	Time-limited elevation (PIM)	IT Administrator
P-02	Multi-factor authentication	Security defaults enabled	Conditional Access policies	IT Administrator
P-03	Administrative account separation	Separate administrative accounts; two emergency accounts	PIM	IT Administrator
P-04	Secure device configuration	Disk encryption, patching, antimalware, no daily local admin	Central device management	IT Administrator
P-05	Patching and updates	Documented routine with timeframes	Managed update rings	IT Administrator
P-06	Network segmentation	Staff, guest, and management VLANs; default-deny rules	Not required	IT Administrator
P-07	Secure remote access	Identity-based access to cloud services; no VPN by default	Private connectivity only if required	IT Administrator and Cloud Administrator
P-08	Secrets management	Application secrets in a key vault, never in source code	Automated rotation	Cloud Administrator
P-09	Logging and audit	Sign-in, audit, and firewall logs retained and reviewed	Central log analytics	IT Administrator and Cloud Administrator
P-10	Backup protection	Separate protection for Azure workloads and Microsoft 365 data; restore tests	Dedicated Microsoft 365 backup (if needed)	IT Administrator and Cloud Administrator
P-11	Access reviews	Scheduled reviews	Automated access reviews	Management
P-12	Joiner, mover, leaver	Documented checklist	Automation	IT Administrator and Management

#	Policy	Baseline	Enhanced	Owner
P-13	Acceptable use and data handling	Short staff rules; company data on company-managed devices	Data-loss prevention tooling	Management

3. Policies

P-01 Least privilege and access control

- Access is granted according to the access control matrix and through **groups**.
- No developer holds standing administrator access to Production.
- Azure roles are assigned at the narrowest practical scope, because role assignments at a higher scope apply to everything beneath it.
- Exceptions are time-limited, recorded, and removed afterwards.

P-02 Multi-factor authentication

- All users **must** use MFA. In the baseline this is enforced by **security defaults**, which Microsoft documents as available at no extra cost.
- Legacy authentication is blocked (security defaults do this).
- Where Conditional Access is licensed and adopted, it **replaces** security defaults, and the equivalent protections must be recreated explicitly before switching, including MFA for administrators, MFA for all users, and blocking of legacy authentication.
- Phishing-resistant methods are preferred where supported.

P-03 Administrative account separation

- Administration is performed only with a **separate administrative account**.
- Administrative accounts do not read email or browse the web for daily work.
- The number of accounts with the highest-privilege role is kept very small.
- Two **emergency access accounts** exist, are excluded from sign-in-blocking policies where the platform allows, are monitored for any use, and are tested at least every 90 days, following Microsoft's guidance.

P-04 Secure device configuration

- Company laptops **must** have disk encryption enabled, with recovery keys stored in a controlled, documented location.
- Built-in antimalware **must** be enabled and up to date.
- Employees **must not** use a local administrator account for daily work.
- A device inventory records owner, serial number, and status.
- A lost or stolen device is reported immediately; sessions are revoked and the account is secured according to the lost-device procedure.

P-05 Patching and updates

- Operating system and application updates are applied on a documented routine. Target timeframes are set by the organization; none are invented here.
- Network device firmware is tracked and updated, using vendor-validated sources. This follows the CISA guidance on securing network infrastructure devices cited in the network document.
- Critical security updates are applied outside the routine when a vendor or authority marks them urgent.

P-06 Network segmentation

- Guest and personal devices **must** use the guest network, which has internet access only.

- Management interfaces of network devices are reachable only from the management segment and a designated administration workstation.
- Inter-segment traffic is denied by default; each allowed flow is explicit. VLANs alone are not security; the firewall rules and switch configuration enforce the isolation. Detail is in `../architecture/network-architecture.md`.

P-07 Secure remote access

- Employees reach Microsoft 365 and Azure over the internet using their identity and MFA.
- A VPN is **not** a universal requirement. It is introduced only if a resource actually requires private network connectivity (ADR-005).
- Network devices are not administered from the internet.

P-08 Secrets management

- Application secrets, keys, and certificates **must not** be stored in source code, tickets, or chat.
- They are kept in a key vault service and accessed through managed identities or tightly scoped permissions (Azure design in Phase 5).
- Azure Key Vault is for **application** secrets. It is **not** an employee password manager; employees use an approved password manager.
- Any secret that is exposed is treated as compromised and rotated.

P-09 Logging and audit

- Sign-in logs, audit logs, and firewall logs are retained and reviewed on a schedule.
- Any sign-in by an emergency access account triggers an alert and a documented review.
- Retention periods and alert thresholds are defined in the operations documents. They are not invented here.

P-10 Backup protection

- Azure workloads and Microsoft 365 data are protected **separately**. Azure Backup is not assumed to protect Exchange Online, SharePoint Online, or OneDrive (ADR-006).
- Backups are protected from unauthorized change or deletion, with separate administrative rights where practical.
- A backup is considered proven only after a **successful restore test**.
- Recovery objectives must be derived from business requirements and are not defined in this portfolio (A-06).

P-11 Access reviews

- Administrative roles, group memberships, Azure role assignments, guest accounts, and emergency accounts are reviewed on the schedule in the identity document.
- Findings and removals are recorded.

P-12 Joiner, mover, leaver

- Each change follows the checklists in `../operations/onboarding-offboarding.md`.
- A leaver's access is removed on the **last working day, or earlier if risk requires**, and shared secrets the person knew are rotated (including the staff Wi-Fi passphrase, ADR-009).

P-13 Acceptable use and data handling

- Company data is handled only on company-managed devices and approved services.

- Staff report suspected phishing, lost devices, or unusual account activity immediately.
- Staff must not share accounts or credentials.
- Content of this policy for staff should be short, plain, and acknowledged on joining.

4. Baseline versus licence-dependent controls

Control	Baseline	Needs confirmation
Security defaults (MFA, legacy authentication blocking)	Yes (no licence required, per Microsoft)	—
Conditional Access	No	Requires at least Microsoft Entra ID P1; Microsoft also states Business Premium includes it
Risk-based policies	No	Microsoft Entra ID P2
Privileged Identity Management	No	Microsoft Entra ID P2 or Entra ID Governance
Intune-based device management	No	Intune inclusion depends on the licence; not asserted for Business Premium
Azure RBAC	Yes	Free and included with an Azure subscription, per Microsoft
Firewall segmentation and guest isolation	Yes	Depends on firewall capability (N-03)

Statements are as documented on 2026-11-13 and must be re-verified before use.

5. Policy governance

Item	Rule
Ownership	Each policy has a named owner role (table in section 2)
Review	Reviewed at least yearly and after any significant incident or architecture change
Exceptions	Written, time-limited, approved by management, and tracked
Change	Changes follow the change management process (Phase 7)
Evidence	Adherence is shown by access reviews, logs, and restore-test records, not by assertion

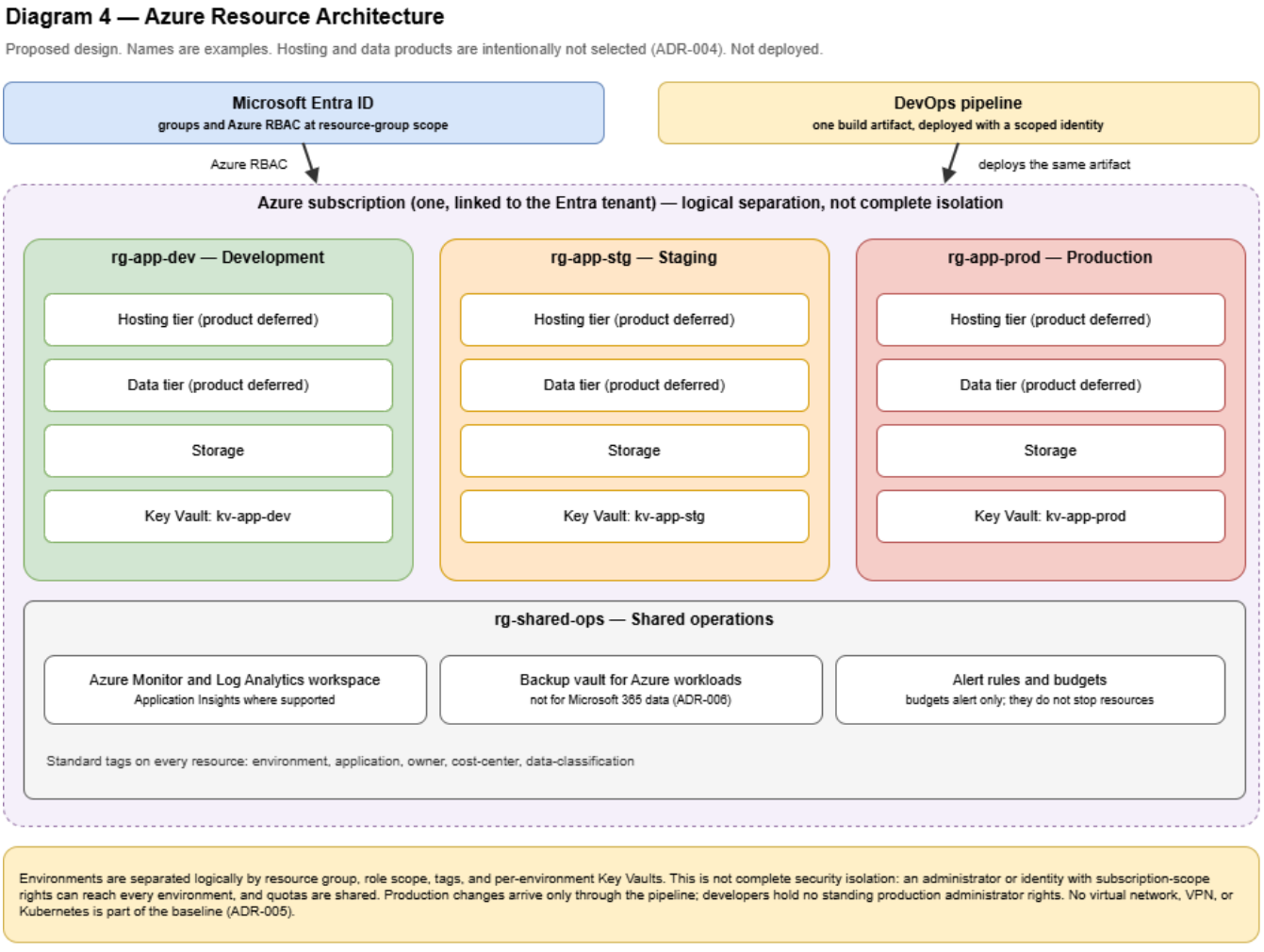
6. Limitations

- These are example policies. A real organization must adapt them to its legal, contractual, and risk context.
- No compliance framework is mapped (A-05).
- Timeframes, retention, and thresholds are deliberately not set here; they depend on business requirements.

Cloud Architecture (Microsoft Azure)

> **Proposed, illustrative design.** Nothing here has been deployed or tested. Resource names, tags, and counts are examples. Assumption IDs (A-nn) refer to `reference-scenario.md`; decisions are in `../decisions/architecture-decisions.md` (ADR-002, ADR-004, ADR-005, ADR-006, ADR-013, ADR-014). Statements about Azure are taken from official Microsoft documentation **accessed 2026-11-13** and must be re-verified before use. Statements marked *author's recommendation* are not Microsoft statements.

Diagram: **Diagram 4 — Azure Resource Architecture** (`diagrams/04-azure-resource-architecture.drawio`).



1. Purpose and scope

This document describes how Azure resources are organized for the reference organization: subscription and resource groups, environment separation, hosting and data tiers, secrets, monitoring, backup, tagging, and cost control.

In scope: logical Azure structure, access boundaries, decision criteria for hosting and data, Key Vault, monitoring, backup, tagging, and cost governance.

Out of scope: a specific hosting or database product (ADR-004, deferred), executable templates (ADR-007), pricing, sizing, and the delivery pipeline (Phase 6).

2. Azure-specific assumptions

ID	Assumption	Consequence
Z-01	One Azure subscription linked to the organization's Entra tenant (A-02, ADR-002)	Environments are separated by resource group, not by subscription
Z-02	Application stack, traffic, and data volume are unknown (A-04)	Hosting and data are shown as generic tiers
Z-03	One primary Azure region	Region choice depends on users, data residency, and service availability; it is not decided here
Z-04	No Azure-hosted private network is required in the baseline (ADR-005)	No virtual network design unless a trigger applies (section 8)
Z-05	Production data is not copied into Development or Staging without a documented approval	Keeps non-production environments out of the sensitive-data scope. *Author's recommendation*

3. Subscription and resource group structure

Baseline (ADR-002): one subscription, with resource groups for each environment and a small set of shared resource groups.

Resource group (illustrative)	Purpose	Contents
`rg-app-dev`	Development environment	Hosting tier, data tier, storage, Key Vault
`rg-app-stg`	Staging environment	Same shape as Production, smaller where sensible
`rg-app-prod`	Production environment	Hosting tier, data tier, storage, Key Vault
`rg-shared-ops`	Shared operations	Log Analytics workspace, Application Insights, backup vault, alert rules

Notes:

- Microsoft states that subscriptions are units of management, billing, and scale, and that they bound scale, quota, cost, governance, security, and identity controls. It also states that development environments typically have more relaxed policies than production, and that using a separate subscription is appropriate when a workload needs a different policy set. A single subscription is therefore a **starting point**, and the conditions that end it are listed in ADR-002.
- Microsoft states that a resource group's region should match the region of its resources and that one resource group should not hold resources from multiple regions.
- The structure repeats per application. A second application adds a new set of environment resource groups, not a new design.

Trade-off — one subscription versus one per environment

Option	Advantage	Disadvantage
One subscription, resource groups per environment (chosen)	Low overhead; one cost view; simple RBAC scopes; easy to document	Quotas and some policies are shared; a subscription-level mistake or compromise affects every environment
One subscription per environment	Stronger isolation; different policies and owners per environment; separate quotas	More administrative work; cross-subscription connectivity must be designed; hard to justify at 15 people without a specific driver

4. Logical separation versus complete security isolation

This distinction matters in design reviews and interviews.

	Logical separation (this design)	Complete security isolation
What it is	Resource groups, RBAC scopes, tags, naming, and policies that keep environments apart in management	Separate subscriptions (or tenants) with their own identities, policies, quotas, and network boundaries
What it prevents	Accidental changes across environments; routine over-broad access	Compromise or misconfiguration in one environment affecting another at the platform level
What it does **not** prevent	A subscription-level administrator or compromised high-privilege identity reaching every environment; shared quotas being exhausted; shared subscription-level settings	Not applicable (but cost and effort are higher)

Consequence for this design: separation depends on correct role assignment at resource-group scope. Azure RBAC is additive: Microsoft's documentation shows that a Contributor assignment at subscription scope makes a narrower Reader assignment beneath it irrelevant. Subscription-scope roles must therefore be rare (ADR-014).

5. Environment characteristics

Aspect	Development	Staging	Production
Purpose	Build and early testing	Validate the release candidate before production	Serve users
Shape	Smallest that works	As close to Production as is justified	Sized to requirements (not defined here)
Human access	Developers and leads can change resources	Leads can change; developers deploy through the pipeline	No standing change rights for developers; changes through the pipeline after approval
Data	Synthetic or anonymized (Z-05)	Synthetic or anonymized	Real data
Secrets	Own Key Vault	Own Key Vault	Own Key Vault
Monitoring	Basic	Full, to test alerts	Full, with alerting and review
Backup	Not required unless data has value	As needed to rehearse restore	Required; restore-tested
Cost control	May be stopped or scaled down outside working hours where the product allows	As needed	Always on as required

Sizing, availability targets, and retention are **not defined** here. They depend on business requirements (A-06).

6. Application hosting and data tiers (deferred)

ADR-004 defers the choice of product. The diagram therefore shows a generic **hosting tier** and **data tier**.

Microsoft's compute decision guidance describes a flowchart that is "only a starting point" and maps needs to services: full control to Virtual Machines, managed web hosting to App Service, event-driven work to Azure Functions, and containers to Container Apps, Container Instances, or AKS. The comparison criteria include team skills and operational overhead, networking, DevOps support, scalability, security, and cost. The page also notes that all listed services are regional.

A neutral comparison and a decision procedure are in ../decisions/technology-comparison.md.

Constraints this design places on whichever product is selected:

1. It must support deployment from a **single immutable build artifact** promoted through the three environments (Phase 6).
2. It must integrate with **managed identities** so that applications do not hold stored credentials (section 7).
3. It must send logs and metrics to the shared monitoring workspace (section 9).
4. Its data must be **recoverable** in a way that can be restore-tested (section 10).
5. It should not require a private network unless a trigger in section 8 applies.

7. Secrets management with Key Vault

Microsoft describes Azure Key Vault as a service for managing **secrets** (tokens, passwords, certificates, API keys), **encryption keys**, and **certificates**. It states that applications should not need to keep security information in code, and that access is authenticated through Microsoft Entra ID and authorized through **Azure RBAC** or a Key Vault access policy.

Decision	Design
Vault granularity	One Key Vault **per environment** (`kv-app-dev`, `kv-app-stg`, `kv-app-prod`). *Author's recommendation.* Microsoft's page describes a vault per application, restricted to a specific application and team, and does not address environments
Authorization model	Azure RBAC for both vault management and data access, assigned to groups and application identities at vault scope
Application access	Managed identities with the narrowest role (for example, read secrets only)
Human access	Developers have no access to the production vault. Cloud administrators manage the vault; secret values are read only when required and the access is logged
Content	Application secrets, keys, and certificates only. **Not** employee passwords (security policy P-08)
Source control	No secrets in source code, tickets, or chat. Exposed secrets are rotated

Trade-off — one vault per environment versus one shared vault

Option	Advantage	Disadvantage
Per environment (chosen)	RBAC boundary matches the environment boundary; Production secrets never share a scope with Development access	More vaults to manage; small extra operational work
One shared vault	Fewer objects	One scope covers every environment; harder to restrict by environment; mistakes can expose Production secrets

Vault tier (Standard or Premium) and recovery protections such as soft delete are **not assessed here** and must be verified when the vault is designed. Vault pricing is not stated.

8. Networking in Azure (only when required)

The baseline has **no** virtual network design. Many managed Azure services are reachable over the internet and are protected by identity, TLS, and service-level access controls.

Trigger	Response
A resource must not be reachable from the internet	Private connectivity for that resource, designed and recorded in a new ADR
Office staff need private access to Azure resources	Evaluate options and trade-offs in a new ADR; VPN is not assumed (ADR-005)
A hosting product requires a virtual network	Design the minimum network for that product

Trigger	Response
Connecting the office and Azure	Plan non-overlapping address ranges first (see `network-architecture.md`, section 11). Microsoft states that virtual networks cannot span subscriptions, which matters if a multi-subscription split is later adopted

Network security groups, firewalls, and private endpoints are not selected in the baseline.

9. Monitoring

Component	Role
Azure Monitor	Platform metrics, activity logs, and alerts
Log Analytics workspace	Central store for logs and queries. Located in `rg-shared-ops`
Application Insights	Application telemetry, **where the application type and hosting product support it**
Entra sign-in and audit logs	Intended to be exported so identity events are retained and alertable (security policy P-09). The export path and the licence it requires are **not verified**; see `../operations/monitoring-and-alerting.md`, section 4
Alerts and action groups	Notify the responsible role; defined in Phase 7

Log Analytics facts from Microsoft's documentation: tables retain data for **30 days by default** (some log tables 90 days); analytics retention can be extended up to **730 days** at extra cost; total retention can reach **12 years** using a lower-cost long-term state; **31 days** of analytics retention are included in the ingestion price; and charges depend on data volume and retention days. Per-GB prices are not stated here.

Trade-off — one workspace versus one per environment

Option	Advantage	Disadvantage
One shared workspace (baseline)	One place to query; simpler to operate and to alert on	Access to logs must be controlled carefully so developers do not read Production logs without need; mixed volumes complicate cost attribution
One workspace per environment	Access and retention can differ per environment; clearer costs	More objects to manage; cross-environment queries are harder

The baseline uses one shared workspace. Revisit when access separation by environment is required. Retention periods and alert thresholds are not defined here; they are set in `operations/monitoring-and-alerting.md` (Phase 7, not yet written).

10. Backup and recovery for Azure workloads

Microsoft's Azure Backup overview names these protectable workloads: Azure Virtual Machines and Disks; SQL Server, SAP HANA, SAP ASE, PostgreSQL, MySQL Flexible Server, and Azure Cosmos DB; Azure Files, Blobs, and Data Lake Storage; and AKS. It describes soft delete, immutable backup, role-based access control, and storage of backup data in a Recovery Services vault isolated from the production environment.

Point	Design
Scope	Only the workloads that the selected hosting and data products actually use. Coverage must be checked against the support matrix after ADR-004 is resolved
Not covered by Azure Backup	The page does **not** list Exchange Online, SharePoint Online, or OneDrive. Microsoft 365 data needs a separate approach (ADR-006)

Point	Design
Protection of backups	Use soft delete and immutability where available; give backup administration to a restricted group. The configuration details are not described on the overview page and must be verified
Where backups live	A backup vault in `rg-shared-ops`, separate from the resource groups it protects
Proof of recovery	A **successful restore test** is the only proof. Test cadence is defined in Phase 7
Objectives	RPO and RTO are **not defined** here and must come from business requirements (A-06)

A successful backup job does not prove that recovery is possible.

11. Tagging and naming

Author's recommendation. The sources reviewed for this phase did not cover tagging, so this section is design guidance rather than a cited Microsoft rule. Verify against current Azure tagging and naming guidance before use.

Tag (illustrative)	Example value	Purpose
`environment`	`dev`, `stg`, `prod`	Filtering, cost views, policy
`application`	`app`	Group resources of one application
`owner`	A role or group, not a personal name	Who is accountable
`cost-center`	`engineering`	Cost allocation
`data-classification`	`internal`, `confidential`	Handling expectations

Naming pattern (illustrative): `<type>-<application>-<environment>`, for example `rg-app-prod`, `kv-app-stg`. Keep names consistent and short. Some Azure resource types have naming restrictions that must be checked per type.

Rules: every resource group and resource carries the minimum tags; tags are checked during the periodic review. Enforcement through Azure Policy is an optional enhancement and is not assumed.

12. Cost governance

Practice	Detail
Visibility	Review cost by resource group and tag on a regular cadence
Budgets	Microsoft documents that budgets **only alert**; "resources aren't affected, and your consumption isn't stopped". Budgets are supported at subscription and resource-group scope and can trigger action groups. Whether budgets themselves carry a charge is not stated on the page
Ownership	Each environment has a named owner role who responds to budget alerts
Right-sizing	Review utilization before increasing size; scale Development and Staging down when idle where the product allows
Deferred or optional	Additional environments, geo-redundancy, premium tiers, long log retention, and extended backup retention are optional and have cost; each requires a requirement behind it

Capability	Core	Optional or deferrable	Cost note
Resource groups, tags, Azure RBAC	Yes		Microsoft states Azure RBAC is free and included with an Azure subscription
Hosting and data tiers	Yes (product deferred)		Cost depends on the product and size
Key Vault	Yes		Pricing not stated here

Capability	Core	Optional or deferrable	Cost note
Monitoring	Yes	Long retention, extra tables	Depends on data volume and retention days
Azure Backup	Yes for data with value	Extended retention, archive	Depends on protected size and retention
Virtual network, firewall, private endpoints	No	Add when a trigger applies	Not assessed
Additional subscriptions	No	Add when a driver applies	Not assessed

No prices are stated or implied.

13. Access model for Azure (summary)

Role assignments follow `../security/access-control-matrix.md` and ADR-014:

- Roles are assigned to **groups**, at **resource-group scope**.
- A small number of administrative accounts hold the roles needed to create resource groups and manage role assignments. Their count is kept minimal.
- Deployment from the pipeline uses a **managed identity or service principal** scoped to the target resource group (Phase 6).
- Developers cannot change Production directly.

14. Growth path

Trigger	Extension
Second application or product	Repeat the environment resource-group set; share `rg-shared-ops`
Different owners, policies, or compliance for Production	Move Production to its own subscription, grouped under a management group (ADR-002)
Private connectivity needed	Virtual network design under a new ADR
Need to enforce standards	Azure Policy for tags, allowed regions, and allowed resource types
More automation	Infrastructure as code (Bicep) with reviewed changes (ADR-007, Phase 6)
Larger team	Separate cloud operations from application ownership

15. Limitations

- Nothing has been created in Azure, and no cost, quota, or capacity has been checked.
- The hosting product, data product, region, size, and availability targets are open.
- Backup and Key Vault protections are described at feature level; their configuration is not verified.
- Tagging and naming guidance is the author's recommendation.

16. Well-Architected quick check (self-review, not an official assessment)

Pillar	Observation
Reliability	Backup and restore testing required; recovery objectives deliberately undefined; no redundancy assumed
Security	Identity-centred access, per-environment vaults, managed identities, no standing production rights; logical (not complete) isolation acknowledged
Cost Optimization	Single subscription, deferred optional services, budgets and tags; no prices claimed

Pillar	Observation
Operational Excellence	Consistent naming and tags, shared monitoring, documented ownership; IaC as a concept
Performance Efficiency	No sizing claims; hosting choice deferred until requirements exist

17. Sources

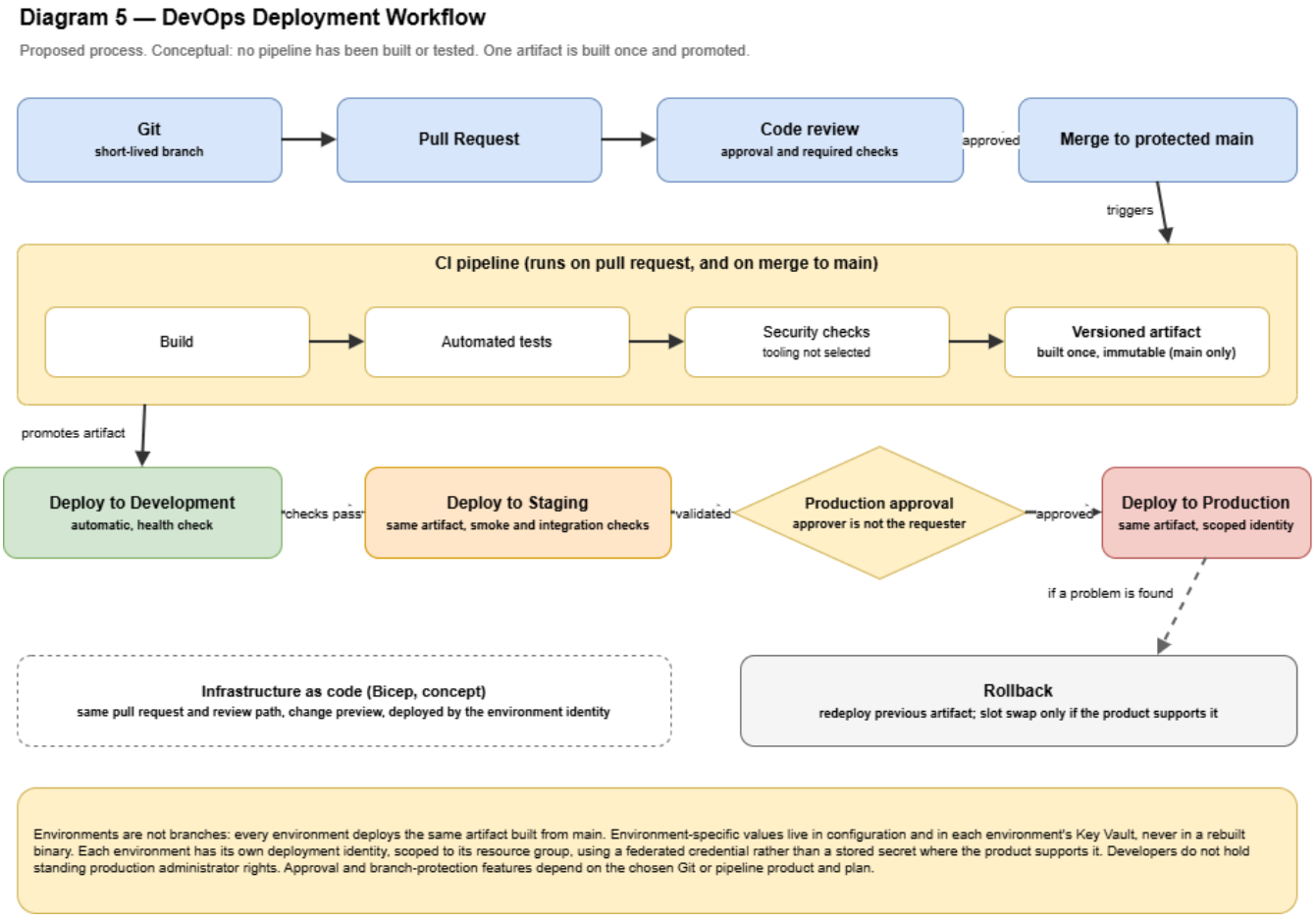
Accessed 2026-11-13. Recommendations beyond these statements are the author's own.

Topic	Source
Subscriptions as units of management, billing, scale; separate subscriptions for different policy sets; resource group region	Cloud Adoption Framework — Subscription considerations and recommendations
Azure RBAC scopes, additive permissions, no extra cost	Microsoft Learn — What is Azure RBAC?
Key Vault purpose and access control	Microsoft Learn — Azure Key Vault overview
Log Analytics retention	Microsoft Learn — Manage data retention in a Log Analytics workspace
Azure Backup workloads and protections	Microsoft Learn — What is Azure Backup?
Compute service selection	Azure Architecture Center — Choose an Azure compute service
Budgets alert only; supported scopes	Microsoft Learn — Create and manage budgets

Infrastructure Design: DevOps and Infrastructure Automation

> **Proposed, conceptual design.** No pipeline, template, or repository configuration has been created or tested. There is no executable code in this document. Folder names, branch names, and role names are examples. Assumption IDs (A-nn) refer to `reference-scenario.md`; decisions are in `../decisions/architecture-decisions.md` (ADR-007, ADR-014, ADR-015, ADR-016, ADR-017). Statements about GitHub and Azure come from official documentation **accessed 2026-11-13** and must be re-verified before use. Statements marked *author's recommendation* are not vendor statements.

Diagram: **Diagram 5 — DevOps Deployment Workflow** (`diagrams/05-devops-deployment-workflow.drawio`).



1. Purpose and scope

This document describes how a change moves from a developer's laptop to Production in the reference organization: source control, review, build, test, artifact handling, promotion through the three environments, production approval, rollback, and how infrastructure itself is managed as code.

In scope: Git workflow, pull requests and review, continuous integration, artifact promotion, deployment identity, production approval, rollback, and Infrastructure as Code (Azure Bicep) as a concept.

Out of scope: executable pipelines or templates (ADR-007), a specific Git or pipeline product (A-09), the application's technology stack (A-04), sizing, and pricing.

2. DevOps-specific assumptions

ID	Assumption	Consequence
D-01	The Git hosting and pipeline product is **not selected** (A-09)	Required capabilities are listed (section 12); product-specific facts are cited only as examples
D-02	The application stack is unknown (A-04)	Build and test steps are described by purpose, not by tool
D-03	About eight engineers contribute (six developers and two leads in the illustrative counts)	Approval rules must work with very few reviewers
D-04	Development, Staging, and Production are separate environments in one subscription (ADR-002)	Promotion changes the target resource group, not the artifact
D-05	Hosting and data products are deferred (ADR-004)	Rollback and database change guidance is product-neutral

3. Principles

1. **Build once, deploy many.** The same immutable artifact moves through every environment.
2. **Environment is configuration, not code.** Differences between environments are held in configuration and secrets, never in rebuilt binaries.
3. **Everything reviewed.** Application code and infrastructure definitions both change through pull requests.
4. **No standing production access.** Production changes arrive only through the pipeline after approval (ADR-012, ADR-014).
5. **No long-lived secrets in the pipeline** where the platform allows an alternative (ADR-017).
6. **Rollback is designed in**, not improvised.
7. **Proportionality.** The process must be followable by eight people without a dedicated release team.

4. Source control and branching

Repository layout (illustrative). One repository per deployable application, and one for infrastructure definitions, or a clearly separated folder within the application repository.

```
app-repository/
├── src/                    application code
├── tests/                  automated tests
└── pipelines/              pipeline definitions (conceptual)

infra-repository/
├── modules/                reusable Bicep modules
└── environments/           parameter files for dev, stg, prod
```

Branching trade-off

Option	Advantage	Disadvantage
A. Short-lived feature branches merged into a protected `main` (chosen, ADR-015)	Simple; one source of truth; fast integration; fits a small team	Needs reliable automated checks; unfinished work must be hidden behind configuration if merged early
B. Long-lived branches per environment (`dev`, `staging`, `prod`)	Intuitive mapping	Branches drift; merges between them are error-prone; it encourages rebuilding per environment, which breaks "build once"
C. GitFlow-style release and hotfix branches	Structured releases	Heavy for eight people; more merge overhead

Rules (ADR-015):

- `main` is always releasable and is protected.
- Branches live for days, not weeks, and are named by purpose (`feature/...`, `fix/...`).
- **Environments are not branches.** Every environment deploys an artifact built from `main`.
- Releases are identified by a version or commit identifier on the artifact, not by a branch.
- Direct pushes to `main` are blocked, including for administrators, where the product allows it.

5. Pull requests and code review

Required before merging into `main`:

Control	Rule (illustrative)
Review	At least one approving review from someone other than the author; two for changes to infrastructure definitions, pipelines, or access. Counts are examples and depend on team size
Automated checks	The CI pipeline (section 6) must pass
Discussion	Review comments are resolved before merging
History	Squash or rebase merges for a readable history (optional)
Sensitive paths	Pipeline definitions and infrastructure definitions require review from a lead or the cloud administrator

GitHub's documentation states that branch protection can require a set number of approving reviews, require status checks to pass, require conversation resolution, require signed commits, enforce linear history, block force pushes and deletions, and restrict who can push. It also states that protected branches are available in public repositories on GitHub Free, and in private repositories on paid plans, and that restricting who can push depends on the plan and on organization ownership. Equivalent features must be confirmed for whichever product is chosen (D-01).

Review guidance (author's recommendation): reviewers check correctness, tests, security impact (secrets, permissions, input handling), operational impact (logging, failure behavior), and whether a change needs a rollback plan. Reviews are a quality and knowledge-sharing control; they do not replace automated checks.

Small-team trade-off. With two leads, a rule that a lead must always approve can become a bottleneck or lead to rubber-stamping. The design therefore permits any engineer to approve routine changes, reserves lead or cloud-administrator approval for sensitive paths, and names an alternate approver.

6. Continuous integration

Triggered by a pull request (verification) and by a merge to `main` (artifact creation).

Stage	Purpose	Notes
Build	Compile or package the application	Fails on warnings the team has agreed to treat as errors
Automated tests	Run unit tests and fast integration tests	Test content and coverage targets are not set here
Static and security checks	Static analysis, dependency vulnerability checks, secret detection	**Tooling is not selected.** Availability depends on the Git or pipeline product and plan and must be confirmed
Artifact creation	Produce **one** versioned, immutable artifact	Only on `main`. Tagged with the commit identifier
Artifact storage	Store the artifact in a repository the pipeline can read	Retention period is not defined here, but it must cover the rollback window (section 10)

Rules:

- The artifact is built **once**. Later stages never rebuild it.
- Checks that fail stop the pipeline; a failing check is not bypassed without a recorded exception.
- Test data contains no production data (Z-05).
- Pipeline logs must not print secrets.

No claim is made about test results, coverage, or the effectiveness of any scanner. None has been run.

7. Artifact promotion and environments

Flow: the artifact is deployed to Development, validated, promoted to Staging, validated again, approved, and promoted to Production. See Diagram 5.

Stage	Trigger	Gate	Who can influence it
Development	Automatic after the artifact is created	Deployment succeeds; basic health check passes	Developers (through merging reviewed code)
Staging	Automatic after Development succeeds, or on request	Smoke tests and agreed integration checks pass; a lead may add a manual check for risky changes	Developers and leads through the pipeline
Production	**Manual request** from a lead	**Explicit approval by a named approver other than the requester**, checks in Staging passed, and the artifact version is the one validated in Staging	Leads request; an authorized approver approves (section 8)

Configuration and secrets. The artifact contains no environment-specific values. Each environment supplies its own configuration and reads application secrets from its own Key Vault through a managed identity (ADR-013). Database or other data-store changes must follow the guidance in section 10.

Trade-off — promotion model

Option	Advantage	Disadvantage
Promote one immutable artifact (chosen, ADR-016)	What was tested is what is deployed; reproducible; quick rollback to a known artifact	Needs artifact storage and disciplined configuration separation
Rebuild for each environment	Simple to start	The tested binary differs from the deployed one; harder to reproduce incidents
Deploy straight from `main` to Production	Fastest	No staging validation; no approval gate; unacceptable risk

8. Production approval

Principle: a human who did not request the deployment confirms that it is intended, that Staging validation passed, and that a rollback path exists.

Element	Design
Approvers	Members of `grp-leads`, with the cloud administrator as an alternate (access matrix)
Separation of duties	The requester cannot approve their own deployment
Preconditions	Pull request merged; checks passed; Staging validated on the same artifact; rollback artifact identified
Record	The approval, approver, artifact version, and time are recorded and linked to the change record (change management, Phase 7)
Timing	Avoid releasing when nobody is available to respond. Specific windows are not defined here
Emergency changes	Follow the emergency path in change management, with after-the-fact review. They still go through the pipeline

Provider capability (example, not a selection). GitHub's documentation states that deployment environments can require up to six reviewers, of whom one needs to approve; can prevent self-review; can restrict which branches or tags can deploy; and can limit environment secrets to jobs that use the environment. It also states that on GitHub Free, Pro, or Team these protection rules, including required reviewers, are available only for **public** repositories, and that private repositories need an appropriate paid plan. A private organization must therefore confirm the product and plan before relying on a built-in approval gate.

Trade-off — where approval lives

Option	Advantage	Disadvantage
Built-in approval in the pipeline product	Enforced by the platform; recorded automatically	Depends on product and plan
Manual approval outside the pipeline (for example a recorded sign-off in a ticket)	Works with any product	Not technically enforced; relies on discipline and review

The baseline is the built-in gate when the product provides it, and otherwise a recorded manual sign-off with restricted pipeline permissions.

9. Deployment identity and secrets

Requirement: the pipeline must authenticate to Azure without a long-lived stored password where possible.

Microsoft documents that GitHub Actions can authenticate to Azure with OpenID Connect, using a Microsoft Entra application or a user-assigned managed identity with a **federated identity credential** that trusts tokens issued by GitHub Actions for a repository. Its instructions store only the client ID, tenant ID, and subscription ID as GitHub secrets, and no client secret is listed. The page says to assign "an appropriate role" and does not itself specify the scope.

Decision	Design (ADR-017)
Method	Federated credential (workload identity federation) instead of a stored client secret. For another pipeline product, support must be verified
Identity per environment	One deployment identity per environment (`dev`, `stg`, `prod`). *Author's recommendation*
Scope	Each identity holds a role only at its own **resource group** (ADR-014). No subscription-scope role for pipeline identities
Role	The narrowest role that lets the pipeline deploy that environment's resources. The exact role must be verified
Production identity	Usable only from jobs that passed the production approval gate and only from `main`
Application secrets	In the environment's Key Vault, read through managed identities, never in the repository (security policy P-08)
Pipeline permissions	Pipeline definitions are protected by review; the pipeline cannot be edited to bypass the approval gate without review

Trade-off — federation versus stored secret

Option	Advantage	Disadvantage
Federated credential (chosen)	No password to leak or rotate; tokens are short-lived and tied to the repository	Setup is more involved; depends on product support; trust configuration must be scoped precisely
Stored service-principal secret	Works anywhere; simple	A long-lived credential in the pipeline; must be rotated and protected; leaks have lasting impact

10. Rollback

Principle: every production deployment has a known way back, and it has been rehearsed in Staging.

Mechanism	How it works	When it applies	Limits
Redeploy the previous artifact (baseline)	Run the deployment of the last known-good artifact through the same pipeline and approval	Any hosting product (ADR-004)	Requires the artifact to be retained; data changes may not be reversible
Slot swap	Swap back to restore the pre-swap state	Only if the selected product supports it. Microsoft documents slots for App Service in the Standard, Premium, or Isolated tier, and states that swapping the same two slots again restores the "last known good site"	Product-specific; some settings are not swapped (Microsoft lists several), and long-running operations in recycled instances are abandoned
Disable a feature through configuration	A feature flag turns off new behavior	If the code was designed with flags	Needs design effort. *Author's recommendation*
Roll forward	Fix and release quickly	When rollback is riskier than fixing	Requires a fast, reliable pipeline

Rules:

- **Decision owner:** the lead on duty decides between rollback and roll forward and records why.
- **Trigger:** defined by agreed signals, for example failed health checks or sustained errors after release. Thresholds are not set here.
- **Retention:** retain at least the last known-good artifacts for the rollback window. The window is not defined here.
- **Data changes (author's recommendation):** design database or data-store changes to be backward compatible with the previous version (for example, add before removing) so a rollback of the application does not require a risky data rollback. Data restoration from backup is a recovery action governed by the backup and restore procedures, not a routine rollback.
- **Practice:** rehearse a rollback in Staging periodically.

11. Infrastructure as Code (Azure Bicep, conceptual)

Microsoft describes Bicep as a declarative domain-specific language for deploying Azure resources. It states that Bicep is a transparent abstraction over Azure Resource Manager templates, that deployments are idempotent, that modules enable reuse, that the **what-if** operation previews changes before deployment, and that Azure stores state so no state files need managing. Per ADR-007, Bicep is a **documented concept** here, not a tested deliverable.

Aspect	Design
Source of truth	Infrastructure definitions in the infrastructure repository, versioned and reviewed
Structure	Reusable modules (for example, resource group set, Key Vault, monitoring) and per-environment parameter files
Change path	Pull request, review (two reviewers for production-affecting changes), automated validation, a **preview of changes** attached to the review, then deployment by the environment's pipeline identity
Environments	Same modules, different parameters. Development is used to try changes first
Manual changes	Portal changes in Production are exceptions, recorded and reflected back into the definitions to avoid drift
Scope	Deployments target the environment's resource group with a scoped identity. Creating resource groups needs higher rights and is done by the cloud administrator account (ADR-014)
Secrets	Never in parameter files or definitions; referenced from Key Vault

Trade-off — IaC versus portal-managed infrastructure

Option	Advantage	Disadvantage
IaC with review (chosen as the target)	Repeatable; reviewable; consistent environments; recoverable definitions	Learning curve; discipline needed to avoid drift; mistakes are applied at scale
Portal-managed	Fast for small changes; no tooling	Not reproducible; no review trail; environments diverge

Trade-off — IaC language

Option	Advantage	Disadvantage
Bicep	Azure-native; the documentation describes it as transparent over Resource Manager templates	Azure-only
Multi-cloud IaC tooling	Works across providers	Additional tooling and state handling; not assessed here, and the scope is Azure

This portfolio does not publish Bicep templates. If a sandbox becomes available, selected modules could be validated and marked *Implemented* (ADR-007).

12. Required capabilities of the Git and pipeline product (D-01)

The product is not selected. Whichever product is chosen must provide:

Capability	Why
Protected branches with required reviews and status checks	Section 5
Pull request review with comments and resolution	Section 5
Pipelines triggered by pull requests and merges	Section 6
Artifact storage with retention control	Sections 6 and 10
Environment-scoped secrets and approval gates	Section 8
Federated authentication to Azure (or a comparable short-lived mechanism)	Section 9
Audit log of merges, deployments, and approvals	Evidence for reviews
Cost and plan model that fits a 15-person private organization	The requirement that gates are available on the chosen plan

The selection is a separate decision and is not made here.

13. Access and responsibilities

Role	Pipeline and repository responsibilities
Developer	Creates branches and pull requests; reviews others' changes; sees Development and Staging deployments
Senior Developer / Team Lead	Reviews sensitive paths; requests Production deployments; approves Production deployments requested by others; decides rollback
Cloud Administrator	Manages deployment identities, resource groups, and infrastructure definitions; alternate approver
IT Administrator	Manages repository and pipeline platform access, joiner and leaver steps
Management	Receives release information; does not approve technical deployments

This follows the access control matrix: developers deploy to Development and Staging through the pipeline and do not hold production administrator rights.

14. Measuring whether the process works (author's suggestion)

Track a few outcomes without setting targets here: how long a change takes to reach Production, how often Production is deployed, how often a deployment needs a rollback or a fix, and how long it takes to recover. Targets depend on the business and are not defined.

15. Growth path

Trigger	Extension
More applications	Shared pipeline templates and common modules
More engineers	More reviewers, code-owner rules, merge queues
Compliance or customer demand	Stronger evidence trails, signed commits and artifacts
Higher release frequency	Progressive delivery (gradual traffic shifting) where the hosting product supports it
Production moves to its own subscription	Production pipeline and identity moved with it (ADR-002)

16. Limitations

- No pipeline, template, or repository setting has been created or tested.
- The Git and pipeline product, the hosting product, and the test tooling are open.
- Approval and protection features depend on product and plan; GitHub facts are examples.
- Rollback behavior is described at concept level; product-specific details need verification.
- Thresholds, retention periods, and release windows are not defined.

17. Well-Architected quick check (self-review, not an official assessment)

Pillar	Observation
Reliability	Staging validation, rollback designed in and rehearsed; recovery objectives deliberately undefined
Security	Reviewed changes, no standing production access, no long-lived stored credential where federation is possible, environment-scoped secrets
Cost Optimization	Small, proportionate process; product and plan decision deferred with cost as a criterion
Operational Excellence	One artifact, consistent environments, IaC with review, recorded approvals
Performance Efficiency	No performance claims; test content is not defined

18. Sources

Accessed 2026-11-13. Recommendations beyond these statements are the author's own.

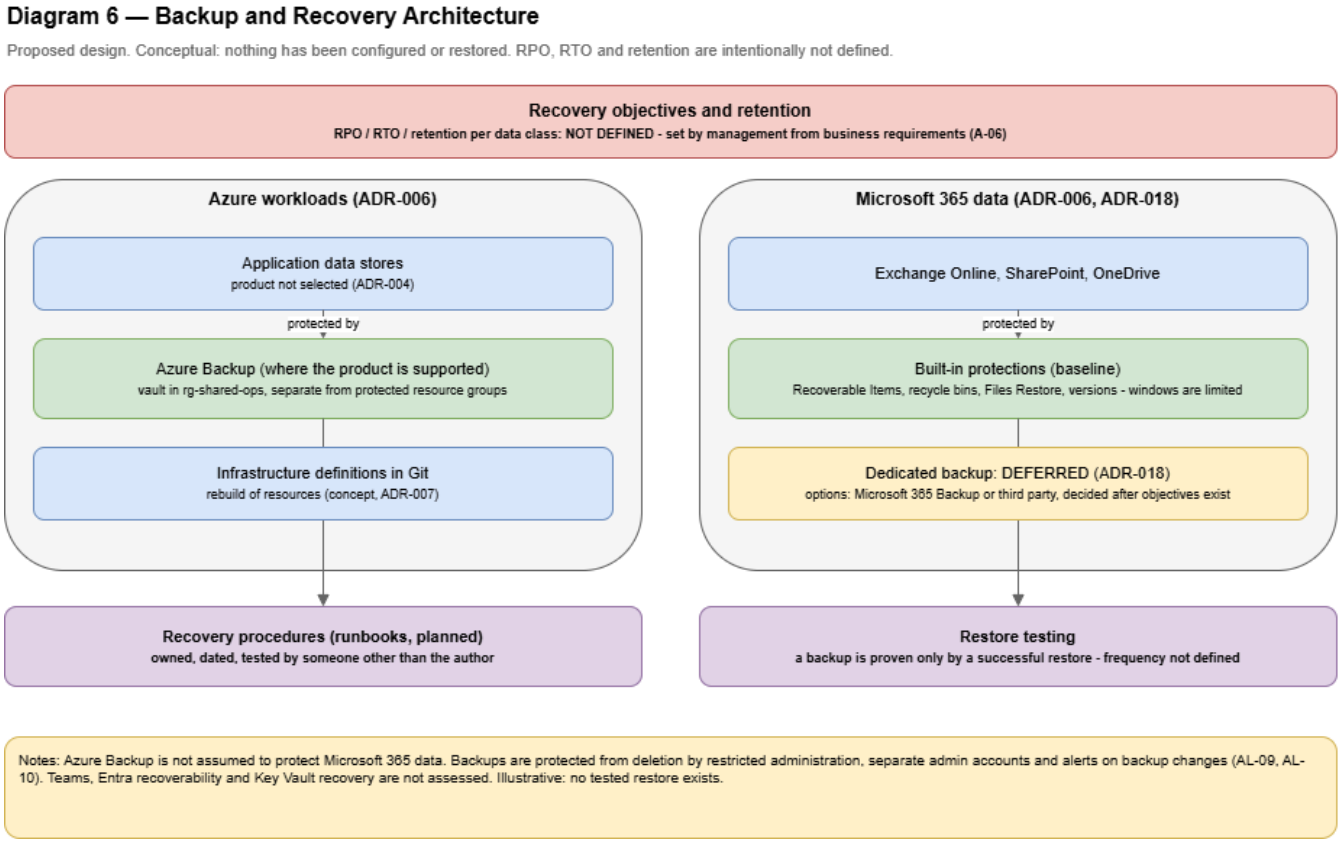
Topic	Source
Branch protection: required reviews, status checks, conversation resolution, signed commits, linear history, force-push blocking, plan availability	GitHub Docs — About protected branches
Deployment environments: required reviewers, self-review prevention, branch restrictions, environment secrets, plan limits	GitHub Docs — Managing environments for deployment
Authenticating GitHub Actions to Azure with OpenID Connect and federated credentials	Microsoft Learn — Authenticate to Azure from GitHub Actions by OpenID Connect
Bicep: declarative, idempotent, modules, what-if, no state files	Microsoft Learn — What is Bicep?

Topic	Source
Deployment slots and swap-back rollback	Microsoft Learn — Set up staging environments in Azure App Service

Backup and Recovery

> **Proposed, illustrative design.** Nothing here has been configured, run, or tested. Recovery objectives (RPO and RTO) and retention periods are **intentionally not defined**: they must come from business requirements (A-06). Assumption IDs (A-nn) refer to `../architecture/reference-scenario.md`; decisions are in `../decisions/architecture-decisions.md` (ADR-006, ADR-018). Statements about Microsoft services come from official documentation **accessed 2026-11-13** and must be re-verified before use. Statements marked *author's recommendation* are not vendor statements.

Diagram: **Diagram 6 — Backup and Recovery Architecture** (`diagrams/06-backup-and-recovery.drawio`).



1. Purpose and scope

This document describes how the reference organization protects its data and how it would recover from loss. It keeps the protection of **Azure workloads** and **Microsoft 365 data** separate (ADR-006), defines a process for setting recovery objectives, and requires restore testing.

In scope: data inventory, protection approach per platform, recovery scenarios, objective-setting process, restore testing, and responsibilities.

Out of scope: product selection for dedicated Microsoft 365 backup, pricing, numeric RPO/RTO and retention values, and detailed restore procedures (see runbooks in `governance-and-runbooks.md`).

2. Principles

1. **A backup is proven only by a successful restore.** A completed backup job is not evidence of recoverability.
2. **Different platforms, different protection.** Azure Backup is not assumed to protect Exchange Online, SharePoint Online, or OneDrive (ADR-006).
3. **Built-in protection is not a recovery plan.** Retention and recycle-bin windows are time-limited features; whether they meet the business need is a decision, not an assumption.
4. **Objectives come from the business.** No RPO, RTO, or retention value is invented here.
5. **Protect the backups.** Backups must resist accidental deletion, malicious deletion, and ransomware.
6. **Rebuildable by design.** Where possible, systems are recreated from reviewed definitions rather than restored as opaque images.

3. Definitions

Term	Meaning
RPO (recovery point objective)	The maximum acceptable amount of data loss, expressed as time
RTO (recovery time objective)	The maximum acceptable time to restore a service after an incident
Backup	A separate, restorable copy of data
Retention	How long recovery points are kept
Restore test	A recorded exercise that restores data or a service and checks it works

4. Data inventory and protection approach

Data or system	Platform	Built-in protection (Microsoft documentation)	Gap to evaluate	Planned approach
Mailboxes	Exchange Online	Recoverable Items folder: deleted items kept **14 days by default, 30 days maximum** if configured; single item recovery can keep purged items for the retention period	Windows are short; not a long-term backup	Built-in baseline plus the decision in section 8
Files in SharePoint and OneDrive	SharePoint Online, OneDrive	Recycle bin **93 days**; Files Restore to any point in the last **30 days** for a document library (uses file versions; default **500** versions for new libraries); metadata backups **14 days**	Windows are limited; versions can be reduced; bulk or malicious overwrite needs more than the recycle bin	Built-in baseline plus the decision in section 8
Teams content	Stored in underlying Microsoft 365 services	Coverage depends on the workload that stores the content	**Not assessed here**; verify per content type	Verify and document
Identity objects (users, groups, roles)	Microsoft Entra ID	Not assessed here. Microsoft publishes tenant recoverability guidance that has not been reviewed in this portfolio	Recreating configuration after a tenant incident	Keep documented configuration in the repository; review Microsoft's tenant recoverability guidance before relying on this
Azure workloads (compute, data, storage)	Azure	Azure Backup supports named workloads (see cloud architecture, section 10)	Coverage depends on the hosting and data products, which are not selected (ADR-004)	Azure Backup for the products actually chosen; verify the support matrix
Infrastructure definitions	Git repository	Versioned, reviewed history	The repository itself needs protection	Hosted repository plus a documented copy or mirror

Data or system	Platform	Built-in protection (Microsoft documentation)	Gap to evaluate	Planned approach
				(author's recommendation); provider not selected (A-09)
Build artifacts	Artifact storage	Retained for the rollback window	Retention is not defined	Retain at least the rollback window (infrastructure design)
Application secrets	Azure Key Vault	Not assessed here; recovery protections must be verified	Accidental deletion of secrets or vaults	Verify recovery protections when the vaults are designed (ADR-013); keep a documented rotation procedure
Network device configurations	Office devices	None by default	Device failure, misconfiguration	Securely stored configuration exports, updated at every change (network architecture)
Company laptops	Endpoint	Data lives in OneDrive or repositories; devices are re-imageable	Locally stored data not synchronized	Policy: work data on approved services; BitLocker recovery keys in controlled custody (identity management)
Emergency access credentials	Offline custody	Not applicable	Loss of the only recovery path into the tenant	Held by authorized individuals in separate secure locations (identity management)

5. Protection design

5.1 Azure workloads

- Protected with **Azure Backup** where the selected product is supported. Microsoft's overview names Azure Virtual Machines and Disks; SQL Server, SAP HANA, SAP ASE, PostgreSQL, MySQL Flexible Server, and Azure Cosmos DB; Azure Files, Blobs, and Data Lake Storage; and AKS. It describes soft delete, immutable backup, role-based access control, and a Recovery Services vault isolated from the production environment.
- Backup vault in `rg-shared-ops`, separate from the resource groups it protects.
- Backup administration is a restricted role held by the cloud administrator's administrative account. Developers have no rights to delete or change backups.
- Soft delete and immutability are used where the product supports them. The configuration details are **not verified** here.
- The rebuild path (infrastructure definitions, build artifacts, Key Vault) is documented so a lost environment can be recreated, not only restored.

5.2 Microsoft 365 data

- **Built-in capabilities** (section 4) form the baseline.
- **Azure Backup does not cover this data.** The Azure Backup overview does not list Exchange Online, SharePoint Online, or OneDrive.
- Whether to add a dedicated backup is a decision tied to RPO, RTO, retention, and cost (section 8 and ADR-018).
- Settings that weaken the built-in protections are controlled: Microsoft notes that reducing the number of file versions reduces the effectiveness of Files Restore, and that values below 100 versions are not recommended.

5.3 Protecting the backups themselves

Risk	Control
Accidental deletion	Soft delete and recycle-bin windows; restricted administrative roles
Malicious deletion or ransomware	Immutability where available; separate administrative accounts (ADR-012); alert on backup changes
Compromised administrator	Separate vault scope; emergency procedures; access reviews
Silent failure	Alerts on backup job failure; recorded restore tests

6. Recovery scenarios

Scenario	First recovery source	Notes
A user deletes a file	Recycle bin or version history	Routine; handled by the IT administrator or the user
A user deletes a mailbox item	Recoverable Items	Within the retention window
Bulk overwrite or ransomware in OneDrive or SharePoint	Files Restore for a library or the chosen backup option	The windows in section 4 limit how far back recovery can go
Compromised account	Containment first (incident response), then restore changed data if needed	See `incident-response.md`
A bad release	Rollback to the previous artifact	Infrastructure design, section 10
Deleted Azure resource or resource group	Rebuild from definitions; restore data from Azure Backup	Depends on product coverage
Lost or stolen laptop	Re-image and restore from OneDrive; revoke access	Identity management
Loss of the only administrator access	Emergency access accounts	Identity management, section 6
Loss of network devices	Replace and apply the stored configuration	Network architecture, section 10
Departing employee data	Data-retention decision before account deletion	Onboarding and offboarding

7. Setting recovery objectives (process only)

RPO, RTO, and retention are decided by the business. This is the process; no value is proposed.

1. **List services and data** from the inventory in section 4.
2. **Assess impact** for each: what stops, who is affected, and what an hour, a day, or a week of loss would mean (financially, contractually, operationally).
3. **Ask the owner** of each service to state the acceptable data loss and the acceptable downtime in their own terms.
4. **Translate** the answers into RPO and RTO and check feasibility against the built-in windows and any backup option.
5. **Record** the agreed values in a table owned by management and reviewed at least yearly.
6. **Prove** them with restore tests that measure the actual recovery time and point.

Service or data	Owner	RPO	RTO	Retention	Agreed on
Mailboxes	To be assigned	**Not defined**	**Not defined**	**Not defined**	—
SharePoint and OneDrive files	To be assigned	**Not defined**	**Not defined**	**Not defined**	—
Production application and data	To be assigned	**Not defined**	**Not defined**	**Not defined**	—
Staging and Development	To be assigned	**Not defined**	**Not defined**	**Not defined**	—
Identity configuration	To be assigned	**Not defined**	**Not defined**	**Not defined**	—

8. Decision: dedicated Microsoft 365 backup

This decision is **deferred** until the objectives in section 7 exist (ADR-018).

Option	What the documentation states	Advantage	Disadvantage
A. Built-in protection only	Windows listed in section 4	No additional cost or tooling	Limited windows; may not meet the objectives; recovery from bulk malicious change depends on versions and recycle bin
B. Microsoft 365 Backup	A pay-as-you-go, consumption-based service covering SharePoint, OneDrive, and Exchange; recovery points every 10 minutes (for a period), selectable recovery windows of months to years, granular and full restores, and a separate recovery window that Purview retention policies do not affect. The page states no licence prerequisites. It lists a per-GiB monthly rate and states that restores are free; **the rate is not reproduced here and must be checked**	Microsoft-native; fast restores; longer windows	Cost grows with protected data; scope is limited to the named workloads; must be evaluated against the organization's needs
C. Third-party backup service	Not assessed here	Possible independence from the platform; broader scope	Additional vendor, cost, and access to the tenant; due diligence required

Recommendation: start with option A and document its limits, then choose between A, B, and C after the objectives are set and a restore test shows whether the windows are sufficient. This is the author's recommendation.

9. Restore testing

Requirement: every protected data class has a recorded restore test. The **frequency is set by the data owner and is not defined here**. A first test is performed before the service is relied upon and after significant changes.

Test type	What it proves
Single file or mail item restore	Day-to-day recovery works and staff know how
Library, site, or mailbox restore	Larger-scale recovery works within the available window
Azure data restore to an isolated location	Backups are valid and restorable without touching Production
Rebuild from definitions	A lost environment can be recreated (infrastructure design)
Credential and access recovery	Emergency access accounts work (identity management)

Each test records: date, scenario, who performed it, the data restored, how long it took, whether the data was usable, and issues found with owners and due dates. The measured times and points are the **evidence** for RPO and RTO.

10. Roles

Role	Responsibility
IT Administrator	Microsoft 365 protection settings, Microsoft 365 restores, device configuration exports
Cloud Administrator	Azure backup configuration and Azure restores, rebuild from definitions
Data or service owner	Sets objectives, approves restores, accepts test results
Management	Owns the objectives table and funding decisions

11. Growth path

Trigger	Extension
Objectives not met by built-in windows	Dedicated Microsoft 365 backup (option B or C)
Hosting and data products selected	Product-specific backup and restore procedures
Compliance or contractual retention	Retention policies and legal hold, reviewed with legal advice
Multiple regions or sites	Redundancy and failover design, driven by RTO
More automation	Automated restore tests and reporting

12. Limitations

- Nothing has been configured or restored. No claim is made about the effectiveness of any backup.
- RPO, RTO, and retention are not defined.
- Teams content, Entra recoverability, Key Vault recovery protections, Azure Backup configuration details, and third-party services are not assessed.
- Microsoft's retention windows and service features may change; re-verify before use.

13. Well-Architected quick check (self-review, not an official assessment)

Pillar	Observation
Reliability	Separate protection per platform, restore testing, rebuild path; objectives deliberately undefined
Security	Restricted backup administration, protection of the backups themselves
Cost Optimization	Built-in baseline first; paid options deferred until justified; no prices claimed
Operational Excellence	Recorded tests, named roles, objective-setting process
Performance Efficiency	Not materially applicable

14. Sources

Accessed 2026-11-13. Recommendations beyond these statements are the author's own.

Topic	Source
Exchange Online Recoverable Items: retention days, single item recovery	Microsoft Learn — Recoverable Items folder in Exchange Online
SharePoint and OneDrive: recycle bin, Files Restore, versioning, metadata backups	Microsoft Learn — SharePoint and OneDrive data resiliency in Microsoft 365
Microsoft 365 Backup: workloads, cost model, recovery points and windows, relation to Purview policies	Microsoft Learn — Overview of Microsoft 365 Backup
Azure Backup supported workloads and protections	Microsoft Learn — What is Azure Backup?
Protected and tested backups as an incident-readiness practice	NIST SP 800-61 Rev. 3

Monitoring and Alerting

> **Proposed, illustrative design.** Nothing here has been configured or tested. **Thresholds, retention periods, and response times are intentionally not defined**; they depend on business requirements and on the products selected. Assumption IDs (A-nn) refer to `../architecture/reference-scenario.md`; decisions are in `../decisions/architecture-decisions.md` (ADR-020). Statements about Microsoft services come from official documentation **accessed 2026-11-13** and must be re-verified before use. Statements marked *author's recommendation* are not vendor statements.

1. Purpose and scope

This document describes what the reference organization watches, where the data goes, how alerts are designed and routed, and how the results are reviewed.

In scope: signals per domain, logging and retention facts, alert design, an illustrative alert catalogue, access to monitoring data, and review routines.

Out of scope: product selection for a network monitoring tool, numeric thresholds, on-call arrangements, and pricing.

2. Principles

1. **Alert on what needs a human action.** An alert without an owner and a first action is noise.
2. **Few, meaningful alerts.** Start small and add alerts when an incident shows a gap.
3. **Every alert has an owner and a route.**
4. **Logs are evidence.** Logs that matter for security and audit are retained and reviewable.
5. **Monitoring itself is monitored.** Silent failure of monitoring or backup is an incident.
6. **Thresholds follow requirements.** None are invented here.

3. What is monitored

Domain	Signals	Why
Identity	Sign-in activity, failed and risky sign-ins, changes to administrative roles and groups, any use of emergency access accounts, changes to authentication policy	Identity is the primary security perimeter (overview)
Microsoft 365	Service notices relevant to the tenant, unusual mailbox or file activity, changes to retention or versioning settings	Detect abuse and protect recovery options
Office network	Internet link and device availability, firewall denied traffic and administrative logins, firmware status	Network architecture, section 9
Azure platform	Activity log (who changed what), resource health, role-assignment changes, budget alerts	Control plane auditing and cost control
Application	Availability, errors, performance, dependency failures (Application Insights where supported)	Detect release problems and outages
Delivery pipeline	Failed builds and deployments, production approvals, changes to pipeline definitions	Change integrity
Backup	Backup job failures, changes to backup settings, restore test results	Recoverability
Secrets	Key Vault access by unexpected identities, secret or vault deletion	Secrets protection
Cost	Budget threshold alerts per environment	Cost governance

4. Logging and retention facts

Source	What Microsoft documents	Implication
Microsoft Entra sign-in and audit logs	Retained **seven days** on the Free tier and **30 days** on P1 and P2. Longer retention is possible by routing the data with Azure Monitor to an Azure storage account; Microsoft Purview Audit (Premium) is mentioned as an alternative for organizations with specific E5-level licences	Security investigations need longer than seven days; the export path and the licence required are **not verified here** and must be confirmed
Log Analytics workspace	Tables retain data for 30 days by default (some tables 90 days); analytics retention can be extended at extra cost; charges depend on data volume and retention	Retention is set deliberately per data type (cloud architecture, section 9)
Azure Monitor alerts	Fired alerts are stored for **30 days** and then deleted	Alert history is not a long-term record; incident records must live elsewhere
Exchange mailbox audit entries	Stored in the Recoverable Items folder when mailbox auditing is enabled	Audit data has its own retention limits (backup and recovery document)

Retention policy for logs (to define): the business or a compliance driver sets how long each log class is kept. No period is stated here. Until then, retain at least what the platform provides and record the gap.

Author's recommendation: decide early which logs must outlive the default retention (identity and administrative activity are the strongest candidates) so that evidence exists when an incident is discovered late.

5. Alert design

Microsoft describes an alert rule as the combination of monitored resources, a signal, and conditions. When the conditions are met an alert fires and can start an **action group**, which can send email, SMS, or push notifications or start automated workflows. Alert types include metric, log search, activity log (including Resource Health and Service Health), and smart detection for Application Insights. Alerts can be **stateful** (fire once until resolved) or **stateless** (fire each time the condition is met, as all activity log alerts do), and an alert has a user response state of New, Acknowledged, or Closed. Alert processing rules can suppress or add action groups, for example during planned maintenance. Microsoft's page does not describe severity levels, so the priority model below is the organization's own.

Design rule	Detail
Route to a **shared** mailbox or channel, not to one person	Avoid single points of failure
Distinguish **urgent** from **informational**	Urgent alerts demand immediate action; informational ones are reviewed on a schedule
Use stateful alerts where repeated notifications add no value	Reduces alert fatigue
Suppress notifications during planned maintenance	With alert processing rules, linked to the change record
Review alerts that never fire or always fire	Remove or repair them
Record the first action in a runbook	See `governance-and-runbooks.md`

Cost note: Microsoft states that metric alert rules are charged by the number of time series monitored, and that log search alerts that split by dimensions are charged by the time series created, with no additional cost for the alert if the data is already in a Log Analytics workspace. Pricing figures are not stated here.

6. Priority model (author's own)

Priorities link alerts to incident response. They are not Microsoft severity levels.

Priority	Meaning (illustrative)	Examples
P1 Urgent	Significant business impact or active security compromise	Production unavailable; emergency account sign-in; suspected account takeover
P2 High	Degraded service or elevated risk without total loss	Repeated deployment failures; backup failures; budget overspend trend
P3 Normal	Minor or planned work	A single non-critical device offline; informational warnings

Response times for each priority are **not defined** here. They are set when the organization defines its service expectations.

7. Alert catalogue (illustrative, thresholds not defined)

ID	Signal	Condition (qualitative)	Route	Owner	Priority
AL-01	Emergency access account sign-in	Any sign-in	Shared admin channel, immediate	IT Administrator	P1
AL-02	Administrative role or group membership change	Any change	Shared admin channel	IT Administrator	P2
AL-03	Sign-in anomalies	Repeated failures or unusual locations (rule design depends on the licence)	Shared admin channel	IT Administrator	P2
AL-04	Production availability	Probe failing or error rate above an agreed level (to be set)	On-call route	Cloud Administrator	P1
AL-05	Production errors or latency	Above an agreed level (to be set)	Team channel	Team lead	P2
AL-06	Deployment failure	Pipeline deployment fails	Team channel	Team lead	P2
AL-07	Azure role-assignment change	Any change at subscription or resource-group scope	Shared admin channel	Cloud Administrator	P2
AL-08	Resource deletion in Production	Delete operation in the Production resource group	Shared admin channel	Cloud Administrator	P2
AL-09	Backup job failure	Any failure	Shared admin channel	Owner of the data class	P2
AL-10	Backup configuration change	Policy or retention change	Shared admin channel	Cloud or IT Administrator	P2
AL-11	Key Vault access anomaly	Access by an unexpected identity	Shared admin channel	Cloud Administrator	P2
AL-12	Budget threshold	Threshold reached per environment (percentages to be set)	Budget owner	Environment owner	P3
AL-13	Office link or device down	Unreachable for a defined duration (to be set)	Shared admin channel	IT Administrator	P2
AL-14	Firewall administrative login or configuration change	Any	Shared admin channel	IT Administrator	P2

Microsoft states that budgets only alert and do not stop resources, so AL-12 is a notification that needs a human decision.

8. Network monitoring decision

The network architecture deferred the monitoring approach to this document. The baseline is **built-in device dashboards and scheduled checks** (availability checks of the link, firewall, switch, and access points; log review; configuration and firmware tracking). A **cloud-managed vendor service** is an optional enhancement if it is available with the chosen devices, with the licence and cost verified. A **self-hosted monitoring tool** is not assumed, because there are no on-premises servers (N-02). See ADR-020.

9. Access to monitoring data

Role	Access (illustrative)
Developers	Read access to Development and Staging telemetry
Senior developers and leads	Read access to all environments' application telemetry
IT Administrator	Administration of identity and Microsoft 365 monitoring
Cloud Administrator	Administration of Azure monitoring and alert rules
Management	Summary dashboards

Microsoft documents built-in roles **Monitoring Contributor** (create and manage alerts) and **Monitoring Reader** (view alerts and resources), and states that creating an alert rule needs read permission on the target resource, write permission on the resource group where the rule is created, and read permission on any associated action group. Role names and the mapping to groups must be verified before use. Access to production logs is limited, because logs can contain sensitive data.

10. Review routines

Routine	Frequency (illustrative)	Owner
Review of fired alerts, and of alerts that never fire	Monthly	IT Administrator and Cloud Administrator
Review of privileged and emergency account activity	Monthly	IT Administrator
Review of denied inter-zone traffic and device logins	Monthly	IT Administrator
Review of cost and budget alerts	Monthly	Environment owners
Review of dashboards and alert catalogue after each incident	After every P1 and P2	Incident lead
Test of the notification route (a deliberate test alert)	At least when routes change	Alert owner

Frequencies are illustrative.

11. Growth path

Trigger	Extension
More services or environments	Standard alert templates deployed through infrastructure as code
Security needs grow	Central security monitoring with correlation, evaluated against licence and cost
Compliance or customer demand	Defined log retention and evidence reporting
After-hours coverage required	On-call rota and escalation policy
Hosting product selected	Product-specific health signals added

12. Limitations

- No alert, dashboard, or log export has been created or tested.
- Thresholds, retention, response times, and on-call arrangements are not defined.
- Entra log export paths and their licence requirements, Microsoft 365 service-notice mechanisms, and rule design for sign-in anomalies are not verified.
- Product selection for network monitoring is open.

13. Well-Architected quick check (self-review, not an official assessment)

Pillar	Observation
Reliability	Availability signals and backup monitoring; no objectives invented
Security	Identity, privilege, and secret-access alerts; log retention gap acknowledged
Cost Optimization	Small alert set; alert and log cost drivers named; budgets monitored
Operational Excellence	Owners, routes, runbooks, and review routines defined
Performance Efficiency	Application performance signals included; thresholds deliberately undefined

14. Sources

Accessed 2026-11-13. Recommendations beyond these statements are the author's own.

Topic	Source
Entra log retention by licence and export options	Microsoft Learn — Microsoft Entra data retention
Alert types, action groups, alert states, processing rules, retention, roles, cost drivers	Microsoft Learn — Overview of Azure Monitor alerts
Log Analytics retention	Microsoft Learn — Manage data retention in a Log Analytics workspace
Budgets only alert	Microsoft Learn — Create and manage budgets
Exchange mailbox audit entries in Recoverable Items	Microsoft Learn — Recoverable Items folder in Exchange Online

Incident and Problem Management

> **Proposed, illustrative process** for a fictional 15-person organization. It has not been exercised. Response times, escalation contacts, legal notification duties, and thresholds are **intentionally not defined**. Assumption IDs (A-nn) refer to `../architecture/reference-scenario.md`; decisions are in `../decisions/architecture-decisions.md` (ADR-019, ADR-020). The structure follows the published guidance of NIST SP 800-61 Rev. 3 (accessed 2026-11-13). Statements marked *author's recommendation* are not NIST statements.

1. Purpose and scope

This document defines how the organization detects, handles, and learns from incidents, and how it removes the causes of repeated incidents (problem management).

In scope: roles, priority model, lifecycle, first actions by incident type, three playbook outlines, communication, evidence handling, problem management, and post-incident review.

Out of scope: legal or regulatory notification procedures (no framework is assumed, A-05), forensic investigation methods, on-call rota, and tooling selection.

Definitions.

Term	Meaning
Event	Any observable occurrence in systems
Incident	An event, or a set of events, that harms or threatens operations, security, or data, and needs a response
Problem	The underlying cause of one or more incidents
Service restoration	Returning to normal operation, which may precede root-cause removal

2. Approach

NIST SP 800-61 Rev. 3 treats incident response as part of cybersecurity risk management and aligns it to the NIST Cybersecurity Framework 2.0 functions. According to the document, Govern, Identify, and Protect prepare for incidents and reduce their impact; Detect, Respond, and Recover cover finding, managing, containing, eradicating, and recovering from them; and lessons learned feed improvement across all functions. It also states that organizations should use whichever life cycle model suits them best. Among its recommendations are documenting roles and authority, keeping response plans current and aligned with business continuity plans, maintaining protected and tested backups, prioritizing incidents by risk factors such as asset criticality and functional impact rather than first-come first-served, restoring from clean backups and verifying them, and sharing lessons as soon as they are identified.

The organization uses a **simple seven-step lifecycle**, mapped to those ideas (ADR-019):

Step	Meaning	NIST emphasis
1. Prepare	Roles, runbooks, monitoring, tested backups	Govern, Identify, Protect
2. Detect and report	Alerts, user reports, vendor notices	Detect
3. Triage	Validate, categorize, prioritize	Detect and Respond
4. Contain	Stop the spread or the harm	Respond

Step	Meaning	NIST emphasis
5. Eradicate and recover	Remove the cause, restore service, verify	Respond and Recover
6. Close	Declare the end by criteria and record it	Recover
7. Review and improve	Review, actions, problem management	Improvement

3. Roles

Role	Held by (illustrative)	Responsibility
Incident lead	IT Administrator by default; Cloud Administrator for Azure incidents	Owns the incident, assigns work, keeps the record, decides escalation
Technical responders	Administrators and relevant developers	Investigate, contain, recover
Communications lead	Management	Internal and external communication, decisions on disclosure
Scribe	Any available person	Time-stamped notes of actions and decisions
Service owner	Named per service	Accepts restoration and the cause fix

For a person acting as incident lead, privileged actions use the administrative account (identity management).

4. Priority model

Priority reflects impact and urgency, not arrival order. This is the organization's own model; no response times are set here.

Priority	Criteria (illustrative)
P1 Urgent	Production unavailable or seriously degraded; suspected active compromise; confirmed loss or exposure of sensitive data
P2 High	Partial degradation; credible security risk without confirmed compromise; backup or monitoring failure
P3 Normal	Minor or single-user issue; informational findings

Increase the priority when more assets, more users, or a more sensitive system are affected than first thought.

5. Reporting

- Staff report suspected incidents immediately to the IT Administrator through the agreed channel (for example a shared mailbox or chat channel). Reporting is never penalized.
- Alerts route to the shared channel (monitoring and alerting).
- Every report creates an **incident record** with: ID, reporter, time, summary, affected systems, priority, owner, status.

6. First actions by incident type

Incident type	Contain first	Then
Compromised account	Block sign-in; revoke sessions; reset credentials and authentication methods	Review sign-in and audit logs, mailbox rules, forwarding, and changes made; check for privilege changes
Suspected phishing	Remove the message where possible; warn staff	Check who clicked; treat clicked accounts as potentially compromised

Incident type	Contain first	Then
Lost or stolen device	Revoke sessions; disable the account if risk is high; mark the device	Confirm disk encryption status from the inventory; report
Malware or ransomware	Isolate the device from the network; stop connected sync if needed	Identify scope; restore from clean sources; verify before reconnecting
Leaked secret	Rotate the secret immediately; revoke the credential	Find where it was exposed; review usage logs; fix the process
Production outage or bad release	Decide rollback or roll forward (infrastructure design)	Confirm recovery; record the change
Data deletion or overwrite	Stop further change; identify the scope and the time	Restore from the recovery source (backup and recovery)
Network outage	Check link, firewall, and switch; use a mobile hotspot as a stopgap	Restore configuration; contact the provider
Unauthorized administrative change	Remove or reverse the change; secure the account	Review role assignments; audit the account's activity

7. Playbook outlines

These outlines show the level of detail intended. Full runbooks follow the template in `governance-and-runbooks.md`.

7.1 Compromised user account

1. Open an incident record and set the priority; assume P1 until scope is known.
2. Block sign-in and revoke active sessions for the account.
3. Reset the credentials and re-register authentication methods after confirming the user's identity through a separate channel.
4. Review the account's recent sign-ins, authentication changes, mailbox rules and forwarding, shared-file activity, and any role or group changes.
5. If administrative rights were involved, treat the administrative account as compromised and review changes made with it.
6. Contain: remove malicious rules, rotate any secrets the user could access.
7. Recover: restore deleted or changed data from the recovery source if needed.
8. Close with criteria: no malicious activity for an agreed period, credentials reset, findings recorded.
9. Review (section 10).

7.2 Leaked secret in a repository

1. Rotate or revoke the secret immediately; do not wait for the investigation.
2. Update the application through its normal change path with the new secret from the key vault.
3. Check usage logs for misuse between exposure and rotation.
4. Remove the secret from future use in the code; consider the repository history as exposed.
5. Find the cause (process gap) and add a control, such as secret detection in the pipeline.
6. Record and review.

7.3 Production outage after a release

1. Confirm the outage from monitoring and set the priority.
2. The lead on duty decides rollback or roll forward and records why.
3. Roll back by redeploying the previous artifact (infrastructure design, section 10), or follow the product-specific method.
4. Verify health and customer-facing function.

5. Communicate status to stakeholders.
6. Capture logs and the failing change for analysis.
7. Open a problem record if the cause is not obvious (section 9).

8. Communication and evidence

Topic	Rule
Internal updates	The incident lead posts status updates in one place at agreed intervals for P1 and P2
External communication	Only the communications lead (management) speaks externally
Legal and contractual duties	No framework is assumed (A-05). If personal or customer data may be affected, obtain advice on notification duties early
Evidence	Preserve relevant logs and screenshots before making changes where this does not delay containment; record who did what and when
Access to the incident record	Limited to those who need it, because it may contain sensitive details
Third parties	Contact vendors when platform-side action is needed; record the case numbers

NIST advises consulting legal advice before redirecting attackers to a sandbox and notes that delaying containment can be risky; this organization does not use such techniques.

9. Problem management

Problem management removes causes rather than symptoms.

Step	Detail
Trigger	Every P1; any incident that repeats; any incident without a clear cause
Investigate	Find the root cause using the incident timeline, logs, and change records; use methods such as asking "why" repeatedly
Record	A problem record linked to the incidents; known errors and workarounds are written down
Fix	Raise a change (change management) for the permanent fix, with an owner and due date
Verify	Confirm the problem no longer recurs; close the record
Trend	Quarterly review of incident and problem records for patterns

10. Post-incident review

Held for every P1 and P2, soon after recovery. The goal is learning, not blame.

Section	Content
Summary	What happened, impact, duration, priority
Timeline	Key events with timestamps
Detection	How it was found and how long it took
Response	What worked, what did not
Cause	Root cause and contributing factors
Actions	Specific actions with owners and due dates (changes, runbook updates, new alerts)
Documentation	Which documents and diagrams need updates

Lessons are shared as soon as they are identified, in line with the NIST recommendation, and the actions are tracked to completion.

11. Exercises

Practice the process before it is needed. *Author's recommendation:* run a short tabletop exercise for one scenario (for example a compromised account) periodically, and a rollback rehearsal in Staging. Frequency is not defined here.

12. Growth path

Trigger	Extension
Larger team	Formal on-call rota and escalation tiers
Higher security exposure	Central security monitoring and a managed response service (evaluated for cost and licence)
Compliance or contractual demand	Defined reporting timelines and an evidence retention policy
Frequent incidents of one type	Dedicated problem investigations and automation

13. Limitations

- The process has not been exercised and no incident has been handled.
- Response times, escalation contacts, and notification duties are not defined.
- NIST guidance is general; applying it to a specific organization requires judgment.

14. Sources

Accessed 2026-11-13.

Topic	Source
Incident response life cycle, roles, prioritization, recovery, lessons learned	NIST SP 800-61 Rev. 3 — Incident Response Recommendations and Considerations for Cybersecurity Risk Management

Change Management

> **Proposed, illustrative process** for a fictional 15-person organization. It has not been operated. Approval roles, windows, and thresholds are examples. Assumption IDs (A-nn) refer to `../architecture/reference-scenario.md`; decisions are in `../decisions/architecture-decisions.md` (ADR-016, ADR-019).

1. Purpose and scope

Change management makes sure changes to systems are understood, approved at the right level, reversible where possible, recorded, and communicated, without slowing a small team more than necessary.

In scope: application releases, infrastructure and Azure changes, identity and access changes, Microsoft 365 tenant settings, office network changes, device standards, and policy changes.

Out of scope: tool selection (a simple register is enough, see section 9), and organization-wide project management.

2. Principles

1. **Proportionate.** Low-risk, repeatable changes are pre-approved; risky changes get review.
2. **Every change has an owner and a record.**
3. **Rollback is planned before the change.**
4. **Existing controls are reused.** Application releases already go through pull request review and the production approval gate (infrastructure design); change management does not add a second approval for the same step.
5. **Documentation follows reality.** A change is not finished until the affected documents and diagrams are updated.

3. Change types

Type	Definition	Examples	Approval
Standard	Low risk, well understood, repeatable, with a documented procedure	Onboarding and offboarding steps; adding a user to a group within the access model; routine patching following the routine	Pre-approved; recorded
Normal	Anything that does not meet the standard criteria	Production release; new alert rule; firewall rule change; role-assignment change; infrastructure change; switching MFA from security defaults to Conditional Access	Review and approval before implementation
Emergency	Needed immediately to restore service or contain a security incident	Rollback of a failing release; blocking a compromised account	Verbal or chat approval by the incident lead; written record and review afterwards

When in doubt, treat the change as Normal.

4. Approval by area

Area	Reviewer or approver (illustrative)	Mechanism
Application release	Lead other than the requester	Pull request review and production approval gate (infrastructure design, ADR-016)
Infrastructure as code	Two reviewers including the cloud administrator for production-affecting changes	Pull request review with a change preview
Azure roles and subscription-level settings	Cloud Administrator plus Management for new privileged access	Change record
Entra and Microsoft 365 tenant settings	IT Administrator, with a second administrator reviewing high-impact changes	Change record
Office network (firewall rules, VLANs, Wi-Fi)	IT Administrator, with a second person reviewing rules that open access	Change record and updated network documents
Security policy	Management	Pull request to the policy documents
Backup and retention settings	Data owner and administrator	Change record; weakening a protection needs the owner's approval

5. Process

Step	Action	Owner
1. Request	Describe the change, the reason, the systems affected, and the requested date	Requester
2. Assess	Classify the type; assess risk and impact (section 6); decide whether a test is needed	Change owner
3. Plan	Write the steps, the verification, and the **rollback**; name who performs it	Change owner
4. Approve	Obtain approval according to section 4	Approver
5. Schedule	Choose a time that fits business needs and available people; announce to affected users	Change owner
6. Implement	Carry out the steps; suppress planned alerts if needed	Implementer
7. Verify	Check the result against the planned verification	Implementer and change owner
8. Record	Update the change record, the documentation, and the diagrams	Change owner
9. Review	For failed or emergency changes, review what happened	Change owner and approver

6. Risk and impact checklist

A change is **higher risk** if any answer is yes:

- Does it touch Production, identity, networking, or backup configuration?
- Could it lock people out (for example MFA, Conditional Access, firewall rules, or administrator roles)?
- Could it expose data or widen access?
- Is it hard to reverse?
- Does it affect many users or a critical service?
- Is it being done for the first time?

For changes that could lock out administrators, confirm before starting that the emergency access accounts work and that a second administrator is available.

7. Emergency changes

1. The incident lead approves the change (chat or verbal) and notes the time and reason.

2. The change is performed through the pipeline where possible; direct portal changes in Production are the exception.
3. Within an agreed period afterwards the change is documented and reviewed, and any direct portal change is reflected back into the infrastructure definitions to avoid drift.
4. A post-incident review (incident response, section 10) decides whether a permanent fix is needed.

8. Change records

Field	Content
ID and title	Unique and descriptive
Type	Standard, Normal, or Emergency
Requester and owner	Names or roles
Description and reason	What and why
Systems and users affected	Scope
Risk assessment	Checklist result
Plan, verification, rollback	Steps
Approver and time	Who approved and when
Schedule	Planned time
Outcome	Success, partial, failed, rolled back
Documentation updates	Links to the updated documents

9. Tooling

A **simple register** is sufficient at this size: a ticket list, a shared table, or issues in the Git repository. No product is selected. Pull requests already serve as the record for code and infrastructure changes.

10. Calendar and communication

- Planned changes affecting users are announced in advance through the usual channel. Lead times are not defined here.
- Avoid releasing when nobody is available to respond.
- Periods when changes are restricted (for example around key business events) are set by management and are not defined here.

11. Measuring the process (author's suggestion)

Track the number of changes by type, how many failed or needed rollback, how many emergency changes occurred, and how many incidents were caused by changes. Targets are not defined here.

12. Growth path

Trigger	Extension
More engineers or systems	A change advisory group for high-impact changes
Compliance or customer demand	Stricter evidence, separation of duties, and change windows
Frequent standard changes	Automation of those changes
Many incidents from changes	Stronger testing and progressive delivery

13. Limitations

- The process has not been operated. Time limits, lead times, and windows are not defined.
- Roles are illustrative and depend on who actually holds them.

Governance, Ownership, and Runbooks

> **Proposed, illustrative governance model** for a fictional 15-person organization. Cadences are examples unless a vendor source is cited. Assumption IDs (A-nn) refer to `../architecture/reference-scenario.md`; decisions are in `../decisions/architecture-decisions.md`.

1. Purpose and scope

This document defines who owns what, how resources and documentation are kept under control throughout their life, how cost is governed, which recurring tasks keep the architecture healthy, and how runbooks are written.

In scope: technical ownership, resource lifecycle, cost governance routine, documentation governance, periodic architecture review, recurring task calendar, and the runbook standard.

Out of scope: pricing, tool selection, and HR or legal processes.

2. Technical ownership

Every system has a **named owner role** who is accountable for it and a **backup owner** so that knowledge is not held by one person. Owners are roles (not personal names) in documents; the assignments are recorded separately.

Area	Owner role (illustrative)	Backup	Accountable for
Identity (Entra ID), access reviews	IT Administrator	Cloud Administrator	Accounts, groups, MFA, emergency access
Microsoft 365 tenant	IT Administrator	Cloud Administrator	Settings, licensing, data protection settings
Office network	IT Administrator	Cloud Administrator	Devices, VLAN and IP plan, firewall rules, Wi-Fi
Company laptops	IT Administrator	Cloud Administrator	Inventory, encryption, updates, lifecycle
Azure subscription and shared operations	Cloud Administrator	IT Administrator	Resource groups, roles, monitoring, backup, cost
Development environment	Team lead	A developer lead	Resources, cost, data hygiene
Staging environment	Team lead	A developer lead	Parity with Production, test data
Production environment	Team lead with Cloud Administrator	Second lead	Availability, releases, recovery
Delivery pipeline and repositories	Team lead	Cloud Administrator	Branch protection, approvals, identities
Security policies	Management	IT Administrator	Policy content and exceptions
Backup and recovery objectives	Management	IT Administrator	Objectives table, restore test acceptance

Ownership is shown in resource tags (`owner`) and in the register of runbooks.

3. Resource lifecycle

Phase	Rules
Request and create	Created through the change process; named and tagged to the standard (cloud architecture, section 11); owner assigned; cost expectation stated
Operate	Monitored, backed up as required, patched, reviewed with its owner
Review	Quarterly: is it still needed, correctly sized, correctly tagged, correctly accessed
Retire	Owner approval; data-retention decision made; access removed; backups handled per retention; resources deleted; documentation and diagrams updated

Specific rules:

- Untagged or ownerless resources are flagged for review and removed if nobody claims them.
- Development and Staging resources are reviewed first for savings; scale-down or shutdown outside working hours is considered where the product allows.
- Production deletion is restricted to the cloud administrator account and alerted (monitoring and alerting, AL-08).
- Leavers' accounts, devices, and data follow the offboarding checklist.

4. Cost governance routine

Policy design is in the cloud architecture (section 12). The routine is:

Item	Detail
Cadence	A regular review (illustratively monthly)
Inputs	Cost by resource group and tag; budget alerts; licence counts for Microsoft 365 and Entra
Participants	Cloud Administrator, IT Administrator, environment owners, Management for decisions
Questions	What changed? What is unused? What is oversized? What can be deferred? Do licences match active users?
Outputs	A short record of decisions and actions; budget adjustments
Budget alerts	Alert only; Microsoft states budgets do not stop resources, so a person decides what to do
Licences	Reconciled with the joiner and leaver records so unused licences are reclaimed

No prices or targets are stated in this portfolio.

5. Documentation governance

Rule	Detail
Source of truth	The repository holds the architecture documents and diagram sources
Change path	Pull request with review; reviewer checks consistency with other documents
Status labels	Every document states whether content is proposed, recommended, conceptual, illustrative, or implemented
Diagrams	Source files (`.drawio`) and exported images are updated together
Updating with change	A change is complete only after the affected documents are updated (change management)
Review cadence	At least yearly, and after any significant incident or architecture change
Sensitive content	No real secrets, addresses, or employer information in the repository
Naming	Consistent file, resource, tag, and group naming as defined in each document

6. Periodic architecture review

At least yearly, review the architecture against the Azure Well-Architected pillars (Reliability, Security, Cost Optimization, Operational Excellence, Performance Efficiency) as a practical checklist. This is a self-review and not a Microsoft assessment. Also review:

- Assumptions that may have changed (A-nn) and the conditions listed under "Revisit when" in each ADR.
- Licences and the features that depend on them.
- Whether growth triggers in each document have been reached.

7. Recurring task calendar (illustrative)

Cadences are examples except where a source is cited.

Task	Cadence	Owner	Source or note
Review administrative role membership	Quarterly	Management with IT Administrator	Identity management
Review group and Azure role assignments	Quarterly	Group owners and Cloud Administrator	Identity management
Validate emergency access accounts	At least every 90 days and after staffing or subscription changes	IT Administrator	Microsoft's emergency access guidance (identity management)
Rotate the staff Wi-Fi passphrase	At offboarding of someone who knew it; periodically	IT Administrator	ADR-009
Review firewall rules and switch port settings	Quarterly	IT Administrator	ADR-008
Check firmware and patch status	Routine, with exceptions for urgent advisories	IT Administrator	Network and security policies
Review alerts, logs, and privileged activity	Monthly	IT and Cloud Administrators	Monitoring and alerting
Run restore tests	Set by data owners	Data owners	Backup and recovery
Rehearse a rollback in Staging	Periodically	Team lead	Infrastructure design
Tabletop incident exercise	Periodically	Incident lead	Incident response
Cost review	Monthly	Cloud Administrator	Section 4
Review of policies and documents	Yearly	Management and owners	Section 5
Review of the recovery objectives table	Yearly	Management	Backup and recovery

8. Runbooks

A **runbook** is a short, tested set of steps for a specific recurring operation or response. It lets a different person do the task correctly.

8.1 Standard

Rule	Detail
One purpose per runbook	Easy to find and follow
Written to be used under stress	Short numbered steps, exact names, no assumed knowledge
Owned and dated	Owner, backup owner, last reviewed, last tested
Tested	A runbook is trusted only after someone other than the author has followed it successfully

Rule	Detail
Linked	From the alert, the document, or the incident playbook that uses it
Free of secrets	It says where a secret is kept, never the secret itself
Reviewed	After every use and at least yearly

8.2 Template

```
# Runbook: <title>

Owner: <role>          Backup owner: <role>
Last reviewed: <date>  Last tested: <date> by <role>
Status: Proposed / Illustrative / Implemented

## Purpose
What this runbook achieves and when to use it.

## Preconditions
Access, accounts, tools, approvals needed. Which account to use.

## Steps
1. ...
2. ...
3. ...

## Verification
How to confirm it worked.

## Rollback or recovery
How to undo or recover if it fails.

## Escalation
Who to contact and when.

## Records
What to record, and where.

## Related documents
Links.
```

8.3 Runbook register (planned)

None of these has been written or tested, except the onboarding and offboarding checklists, which are procedures rather than tested runbooks.

Runbook	Trigger	Owner role	Status
Onboard and offboard a user	Joiner or leaver	IT Administrator	Procedure drafted (`onboarding-offboarding.md`)
Respond to a compromised account	Alert or report	IT Administrator	Outline in incident response
Respond to a leaked secret	Alert or report	Cloud Administrator	Outline in incident response
Roll back a production release	Failed release	Team lead	Concept in infrastructure design
Restore a deleted file or mail item	User request	IT Administrator	Planned
Restore a SharePoint library or mailbox	Incident	IT Administrator	Planned

Runbook	Trigger	Owner role	Status
Restore an Azure data store	Incident	Cloud Administrator	Planned, depends on product
Rebuild an environment from definitions	Incident or exercise	Cloud Administrator	Planned
Use emergency access accounts	Administrator lockout	IT Administrator	Planned
Replace or restore a network device	Failure	IT Administrator	Planned
Handle a lost or stolen laptop	Report	IT Administrator	Planned
Rotate the staff Wi-Fi passphrase	Leaver or schedule	IT Administrator	Planned

9. Growth path

Trigger	Extension
More teams or products	Ownership by product; a lightweight governance forum
Compliance or customer demand	Formal policy lifecycle, evidence, and audits
More automation	Runbooks converted into automated, tested workflows
Larger IT function	Separate roles for operations, security, and cloud platform

10. Limitations

- The model has not been operated. Cadences are examples.
- Ownership assignments and runbook contents depend on the real people and tools.
- No tool is selected for registers, tickets, or runbook storage.

Onboarding and Offboarding

> **Proposed, illustrative procedures** for a fictional 15-person organization. They have not been executed or tested. Group and account names are examples. See `../security/identity-management.md` and `../security/access-control-matrix.md` for the design behind them.

1. Purpose

Joining, changing role, and leaving are the moments when access most often goes wrong. This document defines repeatable checklists so access follows the person's role and is removed when it is no longer needed. It supports security policy **P-12**.

2. Principles

1. **Role first:** decide the person's role before creating anything. Access comes from group membership.
2. **One named account** per person; no shared accounts.
3. **Separate administrative accounts** only for people who administer.
4. **Evidence:** each step is recorded (who, what, when) so reviews have something to check.
5. **Remove on time:** a leaver's access is removed on the last working day, or earlier when risk requires.

3. Roles in the process

Role	Responsibility
Hiring manager (Management)	Requests the change, states the role, start or end date, and required access
IT Administrator	Performs identity, device, and Microsoft 365 steps
Cloud Administrator	Performs Azure access steps
Team lead	Confirms technical access needs and confirms handover
The employee	Completes setup and acknowledges the acceptable use rules

4. Onboarding (joiner) checklist

Before the first day

#	Step	Owner
1	Receive a written request with role, start date, and manager	Hiring manager
2	Create the user account with a standard naming convention	IT Administrator
3	Assign licences according to role (verify licence availability first)	IT Administrator
4	Add the user to the role's groups (for example `grp-all-staff`, `grp-developers`)	IT Administrator
5	For technical roles, add Azure access through the role's group; confirm scope (Development, Staging)	Cloud Administrator
6	Prepare the company laptop: encryption enabled, updates applied, antimalware active, no local admin for daily use	IT Administrator
7	Record the device in the inventory	IT Administrator

First day

#	Step	Owner
8	Hand over the device; the user signs in and registers MFA	IT Administrator and employee
9	Explain acceptable use and reporting rules; the employee acknowledges them	IT Administrator
10	Provide the staff Wi-Fi passphrase through a secure channel	IT Administrator
11	Introduce the approved password manager	IT Administrator
12	Confirm the user can reach what the role needs and nothing more	Team lead

For people who will administer

#	Step	Owner
13	Create a **separate administrative account** with only the needed roles	IT Administrator
14	Add it to the appropriate admin group; record the approval	Management
15	Add the person to the next access review	IT Administrator

4a. Mover (change of role)

#	Step	Owner
1	Written request describing the new role and the effective date	Hiring manager
2	Add the new role's groups	IT Administrator
3	**Remove** the old role's groups and any temporary access	IT Administrator
4	Adjust licences if the role requires different ones	IT Administrator
5	Update Azure access through groups	Cloud Administrator
6	Record the change	IT Administrator

Access should be *replaced*, not *accumulated*. A mover who keeps all old access is the usual cause of excess privilege.

5. Offboarding (leaver) checklist

Timing: access is removed on the last working day, or earlier if there is a risk (for example, a dismissal with a conflict or a suspected security issue). Steps 1 to 5 can be performed in advance and scheduled.

#	Step	Owner
1	Receive a written notice with the leaving date and whether it is a risk case	Hiring manager
2	Identify data, mail, shared files, and responsibilities that need a new owner	Team lead
3	Transfer ownership of files, shared mailboxes, and repositories	Team lead and IT Administrator
4	Record any application secrets, service accounts, or shared credentials the person knew	IT Administrator and Cloud Administrator
5	Retrieve the company laptop and any accessories on or before the last day	IT Administrator

On the leaving date

#	Step	Owner
6	**Block sign-in** for the account	IT Administrator
7	**Revoke active sessions** so existing sign-ins end	IT Administrator
8	Remove the user from all groups, including Azure access groups	IT Administrator and Cloud Administrator

#	Step	Owner
9	Disable and later remove any **separate administrative account**	IT Administrator
10	Remove or reassign the licence only **after** the data-retention decision (step 12)	IT Administrator
11	**Rotate shared secrets** the person knew: staff Wi-Fi passphrase (ADR-009), shared credentials, and any application secrets found in step 4	IT Administrator and Cloud Administrator
12	Apply the data-retention decision; delete or archive the account after the agreed period	IT Administrator and Management
13	Wipe and re-image the laptop; update the inventory	IT Administrator
14	Record completion and who performed each step	IT Administrator

Risk cases: perform steps 6 and 7 first and immediately. A forced sign-out can still leave previously issued tokens usable for a limited time, so rotate sensitive secrets promptly.

6. Special cases

Case	Handling
Contractor or temporary worker	Same checklist with an **end date set at creation**; access reviewed at the end date
Person who holds an administrative role	Also remove administrative accounts and review what that account owned; if the person knew emergency access credentials, **change them**
Person who knew the emergency access credentials	Rotate the credentials and re-validate the accounts
Shared mailbox or shared files owned by the leaver	Reassign before deleting the account
Developer with source-control and cloud access	Remove from the repository service and Azure access groups; review recent changes and pipeline permissions

7. Evidence and review

- Keep a simple log for each change: ticket or request, date, who acted, and what was done.
- During each quarterly access review, sample the log against the actual group memberships.
- Any leaver whose access was not removed on time is treated as an incident and the cause is corrected.

8. Limitations

- The checklists describe intent. Exact portal steps and timings depend on the tools and licences in use.
- Data retention periods and deletion timelines are not set here; they depend on legal and business requirements.
- Automation (for example, automated joiner and leaver workflows) is an optional enhancement and is not assumed.

Architecture Decision Records (ADRs)

> **Illustrative decisions.** These ADRs document the reasoning behind a *proposed* design for a fictional 15-person company. They are not decisions made by a real organization. Status values: **Proposed** (in this portfolio) · **Deferred** (intentionally not decided yet). Assumption IDs (A-nn) refer to `architecture/reference-scenario.md`.

Index

ID	Title	Status
ADR-001	Documentation-first portfolio, no live deployment	Proposed
ADR-002	Single Azure subscription with one resource group per environment	Proposed
ADR-003	Microsoft Entra ID as the single identity source; licence-dependent controls kept optional	Proposed
ADR-004	Defer application hosting and database product selection	Deferred
ADR-005	No VPN, Kubernetes, or multi-subscription design by default	Proposed
ADR-006	Treat Microsoft 365 data protection separately from Azure workload backup	Proposed
ADR-007	Use Infrastructure as Code (Azure Bicep) as a documented concept, not a deliverable	Proposed
ADR-008	Three baseline VLANs (Staff, Guest, Management) with the firewall as the single inter-VLAN policy point	Proposed
ADR-009	Shared-passphrase Wi-Fi for staff as the baseline, with 802.1X as the upgrade path	Proposed
ADR-010	Security defaults as the MFA baseline, Conditional Access as the licence-dependent enhancement	Proposed
ADR-011	Documented manual endpoint baseline, with Intune-based management as the licence-dependent upgrade	Proposed
ADR-012	Separate administrative accounts and two emergency access accounts; no standing production administration for developers	Proposed
ADR-013	One Key Vault per environment, Azure RBAC authorization, and managed identities for application access	Proposed
ADR-014	Group-based Azure roles at resource-group scope; subscription-scope roles limited to a minimal set of administrative accounts	Proposed
ADR-015	Short-lived branches merged into a protected main; environments are not branches	Proposed
ADR-016	Promote one immutable artifact through all environments, with manual approval before Production and a designed rollback	Proposed
ADR-017	Federated deployment identity scoped per environment instead of stored pipeline secrets	Proposed
ADR-018	Microsoft 365 recovery posture: built-in protections as baseline, dedicated backup product deferred until RPO and RTO exist	Deferred

ID	Title	Status
ADR-019	Proportionate change management (standard, normal, emergency) reusing pipeline approval, with a NIST-aligned incident lifecycle	Proposed
ADR-020	Small, owner-based alerting baseline; built-in network dashboards; no self-hosted monitoring tool	Proposed

---

ADR-001 — Documentation-first portfolio, no live deployment

1. **Context:** The portfolio author has no paid cloud, server, or software subscriptions and does not want to install a local lab. The scenario organization is assumed to already own its tenants (A-01).
2. **Problem:** How can the work demonstrate infrastructure judgment without a running environment, and without misleading readers?
3. **Options considered:**
    - A) Deploy a lab on free trials or local virtualization.
    - B) Documentation-first: architecture, diagrams, decisions, procedures.
    - C) Publish untested infrastructure code.
4. **Decision:** Option B.
5. **Reasoning:** Architecture quality shows in requirements analysis, trade-offs, and operational thinking, which documentation can demonstrate. Trials expire and local labs conflict with stated constraints. Untested code would imply validation that did not happen.
6. **Advantages:** No cost; reproducible by anyone; focuses on reasoning; honest.
7. **Disadvantages:** No hands-on proof; some details (real portal behaviour, quotas, edge cases) cannot be verified.
8. **Risks:** Readers may mistake design for experience. *Mitigation:* status labels on every document and a "Limitations" section in the README.
9. **Revisit when:** The author gains access to a sandbox environment, at which point selected designs could be implemented and clearly marked *Implemented*.

ADR-002 — Single Azure subscription with one resource group per environment

1. **Context:** Three environments (Development, Staging, Production) and 15 employees (A-10: limited budget).
2. **Problem:** How should Azure resources be organized so environments are manageable and access can be controlled?
3. **Options considered:**
    - A) One subscription, one resource group per environment (possibly more resource groups per environment for shared vs. app resources).
    - B) One subscription per environment.
    - C) One resource group for everything, separated by naming only.
4. **Decision:** Option A as the starting point.
5. **Reasoning:** Azure RBAC, tagging, and policy can be scoped to resource groups, which gives workable access boundaries with minimal administrative overhead. Option C offers no real access boundary. Option B gives stronger isolation but adds overhead that is hard to justify at this size without a specific driver.
6. **Advantages:** Simple billing view; low overhead; clear RBAC scopes; easy to understand and document.
7. **Disadvantages:** Subscription-level limits, quotas, and some policies are shared; a subscription-level mistake or compromise affects all environments.
8. **Risks:** Over-broad roles assigned at subscription scope would nullify the separation. *Mitigation:* assign roles at resource-group scope, restrict Production, keep subscription-level roles to a very small set of

separate admin accounts.
9. **Revisit when:** Compliance or customer requirements demand stronger isolation, Production must be owned by a different team or budget, subscription quotas become limiting, or the organization grows significantly.

> **Note:** Resource-group separation is *logical separation*. It is not the same as complete security isolation; see `architecture/cloud-architecture.md` (Phase 5).

ADR-003 — Microsoft Entra ID as the single identity source; licence-dependent controls kept optional

1. **Context:** Microsoft 365 and Azure both rely on Entra ID (A-02). Licence tiers are unknown (A-03).
2. **Problem:** How to define identity controls without assuming features the organization may not have licensed?
3. **Options considered:**
   - A) Design around premium capabilities (e.g. Conditional Access, Intune) as mandatory.
   - B) Define a baseline that works on any tier, and list premium controls as optional enhancements.
   - C) Use separate identity stores per system.
4. **Decision:** Option B, with Entra ID as the single identity source.
5. **Reasoning:** One identity source simplifies onboarding/offboarding and auditing. A tier-independent baseline avoids unsupported claims; premium features are documented as upgrades with the dependency stated.
6. **Advantages:** Honest about licensing; usable on a limited budget; clear upgrade path.
7. **Disadvantages:** Baseline may offer less granular control than premium options; endpoint management in particular may be limited without the relevant licence.
8. **Risks:** Licensing details change. *Mitigation:* every licensing statement must be verified against current official Microsoft documentation and carry a date and source.
9. **Revisit when:** Licence tiers are confirmed, security requirements increase, or the device fleet grows beyond what manual processes can manage.

> **Verification pending:** Which MFA and baseline-protection options are available at each licence tier will be confirmed from Microsoft Learn in Phase 4. No claim is made here.

ADR-004 — Defer application hosting and database product selection

1. **Context:** The technology stack, traffic, and data requirements are unknown (A-04).
2. **Problem:** The Azure design needs hosting and data tiers, but choosing a product now would be guesswork.
3. **Options considered:**
   - A) Pick a default (e.g. virtual machines or containers) now.
   - B) Document decision criteria and a short comparison of candidate options; choose when requirements are known.
4. **Decision:** Option B — **Deferred**.
5. **Reasoning:** Hosting and database choices depend on the application's runtime, scaling pattern, operational skills, and cost. Defaulting to any single option would contradict the "no unjustified technology" principle.
6. **Advantages:** Avoids overengineering and unsupported assumptions; keeps the design reusable.
7. **Disadvantages:** The Azure diagram will show hosting and database as generic tiers rather than named products.

8. **Risks:** The architecture may look incomplete. *Mitigation:* provide a decision framework and comparison in `decisions/technology-comparison.md`.
9. **Revisit when:** A concrete application profile (runtime, expected load, data model, team skills) is provided.

ADR-005 — No VPN, Kubernetes, or multi-subscription design by default

1. **Context:** Small team, limited budget, and a requirement to avoid overengineering.
2. **Problem:** Which advanced components, if any, belong in the baseline?
3. **Options considered:**
   - A) Include them to show breadth.
   - B) Exclude by default; document the specific triggers that would justify adding each.
4. **Decision:** Option B.
5. **Reasoning:** Each component adds cost and operational burden. A VPN is justified only if resources require private network connectivity; Kubernetes only if container orchestration needs exist; extra subscriptions only for a concrete isolation or governance driver.
6. **Advantages:** Simpler, cheaper, easier to operate and secure.
7. **Disadvantages:** May need rework if requirements change quickly.
8. **Risks:** Under-provisioning relative to future needs. *Mitigation:* documented triggers and growth path.
9. **Revisit when:** Private connectivity to cloud resources is required, workloads need orchestration, or governance needs exceed one subscription.

ADR-006 — Treat Microsoft 365 data protection separately from Azure workload backup

1. **Context:** The organization uses both Microsoft 365 (Exchange Online, SharePoint Online, OneDrive) and Azure workloads.
2. **Problem:** How should backup and recovery be designed so that no data class is silently unprotected?
3. **Options considered:**
   - A) One generic "backup" section covering everything.
   - B) Separate protection approaches for Azure workloads and Microsoft 365 data, each with its own scope, retention, and restore procedure.
4. **Decision:** Option B.
5. **Reasoning:** These are different platforms with different protection mechanisms. Azure workload backup should not be assumed to cover Exchange Online, SharePoint, or OneDrive. Built-in Microsoft 365 retention and recovery features have limits that must be evaluated against business requirements.
6. **Advantages:** Makes coverage gaps visible; supports accurate restore planning.
7. **Disadvantages:** More documentation; possible additional tooling or cost for Microsoft 365 backup.
8. **Risks:** Assuming built-in features meet requirements. *Mitigation:* document the built-in capabilities from official sources in Phase 7 and decide on third-party backup only against defined RPO/RTO.
9. **Revisit when:** RPO/RTO or retention requirements are defined, or after a restore test reveals gaps.

> RPO/RTO values are intentionally not set. They must be derived from business requirements (A-06). A successful backup job does not prove recoverability; restore testing is a required operational activity.

ADR-007 — Use Infrastructure as Code (Azure Bicep) as a documented concept, not a deliverable

1. **Context:** Repeatable infrastructure is good practice, but this portfolio cannot test code (ADR-001).

2. **Problem:** How to represent IaC without publishing unvalidated templates?
3. **Options considered:**
    - A) Full Bicep templates and pipelines.
    - B) Describe the IaC approach, module structure, and review process; include short snippets only if labelled *illustrative, untested*.
    - C) Omit IaC.
4. **Decision:** Option B.
5. **Reasoning:** Azure Bicep is Azure's native declarative IaC language and fits the Azure-first scope. Explaining how IaC fits change management and environment consistency shows understanding without implying tested code.
6. **Advantages:** Honest; relevant; avoids untested artifacts.
7. **Disadvantages:** Cannot demonstrate syntax proficiency or deployment results.
8. **Risks:** Readers expecting working code. *Mitigation:* clear labelling and README limitations.
9. **Revisit when:** A sandbox is available to validate templates, at which point tested modules could be added and marked *Implemented*.

ADR-008 — Three baseline VLANs (Staff, Guest, Management) with the firewall as the single inter-VLAN policy point

1. **Context:** A single office with about 15 employees, company-managed laptops, visitors who need internet access, and network devices that need administration (A-07, N-01, N-02).
2. **Problem:** How much segmentation is justified, and where should traffic between segments be controlled?
3. **Options considered:**
    - A) One flat network for everything.
    - B) Three VLANs (Staff, Guest, Management), with the firewall routing between them and enforcing policy.
    - C) Many VLANs (per team, per device type, plus a server VLAN) with a Layer 3 switch.
4. **Decision:** Option B. A fourth VLAN (shared devices such as a printer) is documented as optional and not deployed in the baseline.
5. **Reasoning:** Guest devices must not reach company resources, and network device management should not be reachable from ordinary devices. These two needs justify separate segments. More segments would add configuration and troubleshooting effort without a requirement behind them. Routing on the firewall gives one place to define and audit policy.
6. **Advantages:** Simple to document and audit; guest isolation; protected management plane; room to add the optional segment.
7. **Disadvantages:** All inter-VLAN traffic crosses the firewall; the firewall is a single point of failure; no isolation between staff devices.
8. **Risks:** Segmentation is only as strong as the firewall rules and the switch port and trunk configuration; a misconfiguration can silently remove isolation. *Mitigation:* explicit default-deny rules, a maintained IP and VLAN table, and periodic review of rules and port settings.
9. **Revisit when:** On-premises servers or shared devices are introduced, headcount or device count grows significantly, a compliance requirement demands finer segmentation, or internal traffic volume makes firewall routing a bottleneck.

> VLAN IDs, subnets, and rules are illustrative. See `architecture/network-architecture.md`.

ADR-009 — Shared-passphrase Wi-Fi for staff as the baseline, with 802.1X as the upgrade path

1. **Context:** Staff Wi-Fi must authenticate devices. The organization is small, has no on-premises servers (N-02), and has not established whether a RADIUS service can be integrated with its identity platform.
2. **Problem:** Which Wi-Fi authentication model fits a 15-person organization without adding unjustified infrastructure?
3. **Options considered:**
    - A) Shared passphrase (WPA3-Personal, or WPA2/WPA3 transition mode for older clients).
    - B) 802.1X with a RADIUS server (WPA2/WPA3-Enterprise).
4. **Decision:** Option A as the baseline, with a documented passphrase-rotation rule at offboarding. Option B is the planned upgrade.
5. **Reasoning:** Option A needs no extra services and is realistic to operate for a small team. Option B gives per-user or per-device control but needs a RADIUS service and credential design whose compatibility with the organization's identity platform must be verified rather than assumed.
6. **Advantages (A):** Simple, no additional infrastructure, quick to roll out.
7. **Disadvantages (A):** A single secret known to everyone; no per-user attribution in logs; rotation requires touching every device.
8. **Risks:** A former employee who knows the passphrase keeps access until it is changed. *Mitigation:* rotate the passphrase at offboarding, keep the staff SSID on company-managed devices only, and keep guests on a separate SSID and VLAN.
9. **Revisit when:** Staff turnover increases, headcount grows, auditability or compliance requires per-user network authentication, or a verified RADIUS option becomes available.

> Support for specific WPA3 modes must be verified on the actual access points and clients. See `architecture/network-architecture.md` for sources.

ADR-010 — Security defaults as the MFA baseline, Conditional Access as the licence-dependent enhancement

1. **Context:** MFA is required, but the licence tier is unknown (A-03, I-03). Microsoft documents security defaults as available at no extra cost, and Conditional Access as requiring at least Microsoft Entra ID P1 (Microsoft also states that Microsoft 365 Business Premium provides Conditional Access). Sources and access date are in `security/identity-management.md`.
2. **Problem:** How should MFA be enforced without assuming a licence that may not exist?
3. **Options considered:**
    - A) Security defaults.
    - B) Conditional Access policies.
    - C) Per-user legacy MFA settings.
4. **Decision:** Option A as the baseline; Option B as the documented enhancement once licensing is confirmed. Option C is not used.
5. **Reasoning:** Security defaults require no licence and cover MFA registration, MFA for administrators, blocking of legacy authentication, and MFA for privileged activities. Conditional Access allows precise control but needs licensing and careful design. Microsoft states that the two are alternatives: security defaults must be disabled before Conditional Access replaces them.
6. **Advantages:** Free and quick; a sound starting point; clear upgrade path.
7. **Disadvantages:** No customization and no exclusions; one setting for everyone; emergency access accounts cannot be excluded.
8. **Risks:** Switching to Conditional Access can leave a gap if protections are not recreated, and a policy error can lock out administrators. *Mitigation:* recreate every protection explicitly before switching, keep emergency access accounts, and test.
9. **Revisit when:** A qualifying licence is confirmed, device-compliance conditions are needed, or exceptions per group or application become necessary.

> Licence statements must be re-verified before use. They are accurate only as of the access date recorded in the identity document.

ADR-011 — Documented manual endpoint baseline, with Intune-based management as the licence-dependent upgrade

1. **Context:** Company-managed Windows laptops (A-08). Microsoft's Intune licensing page states that Intune is included only with the licences listed on its plans and pricing page, and names Microsoft 365 E3, E5, and E7 as examples. It does not name Business Premium, so no claim is made about it.
2. **Problem:** How to secure laptops without assuming that central device management is licensed?
3. **Options considered:**
    - A) A documented manual baseline (encryption, updates, antimalware, no daily local admin, inventory, lost-device procedure).
    - B) Intune-based central management.
    - C) No defined endpoint standard.
4. **Decision:** Option A now; Option B when licensing is confirmed. Option C is rejected.
5. **Reasoning:** A written baseline is achievable at 15 devices and avoids an unverified licence assumption. Central management provides enforcement and reporting but depends on licensing and adds operating effort.
6. **Advantages:** No licence dependency; the standard exists and can be audited manually; clear migration path.
7. **Disadvantages:** Depends on discipline; no central proof of compliance; remote wipe and compliance-based access are unavailable; poor scaling.
8. **Risks:** Configuration drift and undetected non-compliance. *Mitigation:* an inventory, periodic spot checks, and a short documented checklist at device preparation.
9. **Revisit when:** Intune inclusion is confirmed for the organization's licence, the device count grows, or compliance-based access is required.

ADR-012 — Separate administrative accounts and two emergency access accounts; no standing production administration for developers

1. **Context:** A small team where one person may hold several roles (I-04). Production must be protected from routine changes and from compromise of a daily account.
2. **Problem:** How should administrative access be structured so privilege is limited, attributable, and recoverable?
3. **Options considered:**
    - A) Administrators use their daily account with extra roles.
    - B) Separate administrative accounts, two emergency access accounts, and no standing production administration for developers.
    - C) Time-limited elevation for all privileged access (Privileged Identity Management).
4. **Decision:** Option B as the baseline; Option C as an enhancement.
5. **Reasoning:** A daily account is exposed to phishing and malware, so administrative rights should not live on it. Emergency access accounts prevent a lockout. Developers change Production through the reviewed pipeline, not by standing rights. Microsoft states that Privileged Identity Management requires Microsoft Entra ID P2 or Entra ID Governance, so it cannot be a baseline assumption.
6. **Advantages:** Smaller blast radius; attributable actions; recoverable from lockout; no licence dependency.
7. **Disadvantages:** More accounts to manage; administrators switch accounts; permanent administrative roles remain between uses; the emergency accounts need disciplined custody and testing.

8. **Risks:** Neglected emergency accounts, or administrative accounts used for daily work. *Mitigation:* alerts on any emergency sign-in, validation at least every 90 days, regular access reviews, and a rule that administrative accounts are not used for email or browsing.
9. **Revisit when:** Privileged activity grows, a qualifying licence for time-limited elevation is available, or a compliance requirement calls for stricter privileged access control.

ADR-013 — One Key Vault per environment, Azure RBAC authorization, and managed identities for application access

1. **Context:** Applications need secrets, keys, and certificates, and Production secrets must not be reachable by the access given for Development (ADR-002, ADR-012). Microsoft describes Key Vault as a service for secrets, keys, and certificates, with authentication through Microsoft Entra ID and authorization through Azure RBAC or access policies. Its overview describes a vault per application restricted to a specific application and team, and does not address environments.
2. **Problem:** How should vaults be organized, and how should applications and people be authorized?
3. **Options considered:**
    - A) One shared vault for all environments.
    - B) One vault per environment.
    - C) One vault per application and environment.
4. **Decision:** Option B at the baseline, scaling to Option C when several applications exist. Authorization uses Azure RBAC, and applications use managed identities with the narrowest role.
5. **Reasoning:** Matching the vault boundary to the environment boundary lets role assignments keep Production secrets separate from Development access. Managed identities avoid stored credentials. The environment-level choice is the author's recommendation, not a Microsoft statement.
6. **Advantages:** Clear RBAC boundary per environment; no credentials in code or configuration; consistent with the role model.
7. **Disadvantages:** More vaults to manage than a single shared vault; some work to grant each application's identity access.
8. **Risks:** Over-broad roles on the vault, or secrets copied between environments. *Mitigation:* roles at vault scope for groups and identities, no human access to the production vault by developers, access logged, and exposed secrets rotated.
9. **Revisit when:** More applications are hosted, Production moves to its own subscription, hosting selection (ADR-004) changes how identities are issued, or a requirement calls for hardware-backed key protection or other vault features not assessed here.

> Vault tier, recovery protections, and pricing are not assessed in this portfolio. Key Vault is for application secrets and **not** for employee passwords.

ADR-014 — Group-based Azure roles at resource-group scope; subscription-scope roles limited to a minimal set of administrative accounts

1. **Context:** One subscription with resource groups per environment (ADR-002). Microsoft documents that Azure RBAC is additive, that a role assignment combines a principal, a role definition, and a scope, and that scopes run from management group to subscription to resource group to resource. A broad assignment at a higher scope therefore overrides a narrower one beneath it. The access matrix left open whether the cloud administrator needs the Owner role.
2. **Problem:** How should Azure roles be assigned so that environment separation holds and administrative capability is still available?

3. **Options considered:**
    - A) Broad roles at subscription scope for the technical team.
    - B) Roles assigned to groups at resource-group scope, with a minimal set of administrative accounts holding subscription-scope rights.
    - C) Time-limited elevation for all privileged access (Privileged Identity Management).
4. **Decision:** Option B. The Owner role at subscription scope is held only by the separate administrative accounts of the cloud administrator (and at most one deputy). Everyone else receives roles at resource-group scope through groups. The pipeline identity is a managed identity or service principal scoped to the target resource group. Option C is the licence-dependent enhancement.
5. **Reasoning:** Resource-group scope keeps each environment's access separate, and group-based assignment follows role changes. Someone must be able to create resource groups and manage role assignments, so a small number of subscription-scope accounts is unavoidable in a single-subscription design. Time-limited elevation requires Microsoft Entra ID P2 or Entra ID Governance and is not assumed (ADR-012).
6. **Advantages:** Preserves the environment boundary; small, reviewable set of powerful accounts; no licence dependency.
7. **Disadvantages:** The subscription-scope accounts are powerful and permanent without elevation tooling; creating resource groups needs a higher scope than operating inside them.
8. **Risks:** Role creep and subscription-scope assignments made for convenience. *Mitigation:* quarterly review of Azure role assignments at subscription and resource-group scope, no subscription-scope roles for developers, and alerts on changes to role assignments.
9. **Revisit when:** A qualifying licence enables time-limited elevation, a narrower built-in or custom role can replace Owner for the cloud administrator (to be evaluated and verified, not assumed), headcount grows, or Production moves to its own subscription.

> Which built-in role best fits each duty must be verified against the permissions each role actually grants before use. The role names in the access matrix are illustrative.

ADR-015 — Short-lived branches merged into a protected main; environments are not branches

1. **Context:** About eight engineers (D-03), three environments (ADR-002), and a requirement that the same artifact reaches every environment. The Git product is not selected (A-09). GitHub's documentation states that branch protection can require approving reviews, passing status checks, resolved conversations, and can block force pushes, with availability depending on plan and repository type.
2. **Problem:** Which branching model keeps changes reviewed and releasable without heavy process?
3. **Options considered:**
    - A) Short-lived feature branches merged into a protected `main`.
    - B) Long-lived branches per environment.
    - C) GitFlow-style release and hotfix branches.
4. **Decision:** Option A. `main` is protected, always releasable, and every environment deploys an artifact built from it.
5. **Reasoning:** Option B encourages per-environment rebuilds and drift, which contradicts ADR-016. Option C adds merge overhead that a team of this size does not need. Option A keeps a single source of truth and fast integration.
6. **Advantages:** Simple; supports build-once; small merges are easier to review and revert.
7. **Disadvantages:** Relies on dependable automated checks; unfinished work must be hidden behind configuration if merged early; needs review discipline in a small team.
8. **Risks:** Rubber-stamp reviews or a bottleneck with only two leads; branch protection unavailable on a chosen plan. *Mitigation:* any engineer may approve routine changes, sensitive paths need a lead or the

cloud administrator, an alternate approver is named, and the product and plan are checked against section 12 of the infrastructure design.
9. **Revisit when:** The team grows, release cadence needs release branches, a compliance requirement demands stricter controls, or a long-running parallel version must be maintained.

ADR-016 — Promote one immutable artifact through all environments, with manual approval before Production and a designed rollback

1. **Context:** Production must be protected from untested change (ADR-012, ADR-014), and the hosting product is not selected (ADR-004). GitHub's documentation describes environments that can require reviewers, prevent self-review, restrict deployable branches, and scope secrets, and states that on Free, Pro, and Team plans these rules are available only for public repositories. Microsoft documents slot swapping as a rollback mechanism for App Service in specific tiers.
2. **Problem:** How should changes reach Production so that what is tested is what is deployed, a human confirms the release, and recovery is quick?
3. **Options considered:**
    - A) Promote one immutable artifact: Development, Staging, then Production after approval.
    - B) Rebuild for each environment.
    - C) Deploy automatically to Production on every merge.
4. **Decision:** Option A. Production requires explicit approval from a named approver who did not request the deployment. Rollback by redeploying the previous retained artifact is the baseline; slot swap and feature flags are product-dependent additions.
5. **Reasoning:** Building once removes differences between tested and deployed binaries. Separating requester and approver adds a human check at low cost. Redeploying a retained artifact works with any product, whereas slot swap works only where the product supports it.
6. **Advantages:** Reproducible releases; clear audit trail; fast, product-neutral rollback; recorded approvals.
7. **Disadvantages:** Slower than fully automatic release; needs artifact storage and retention; approval depends on a small group; data changes may not be reversible by rolling back the application.
8. **Risks:** Approval becoming a formality, the platform lacking an enforced approval gate on the chosen plan, rollback never rehearsed. *Mitigation:* defined preconditions for approval, a recorded manual sign-off with restricted pipeline permissions as the fallback, backward-compatible data changes, and periodic rollback rehearsals in Staging.
9. **Revisit when:** Release frequency rises, the hosting product is selected and offers progressive delivery, the Git or pipeline product is chosen, or a requirement calls for stronger separation of duties.

> Retention windows, rollback triggers, and release windows are intentionally not defined.

ADR-017 — Federated deployment identity scoped per environment instead of stored pipeline secrets

1. **Context:** The pipeline must deploy to Azure. Microsoft documents that GitHub Actions can authenticate to Azure through OpenID Connect, using a Microsoft Entra application or user-assigned managed identity with a federated identity credential, and its instructions store only identifiers (client, tenant, and subscription IDs), not a client secret. The page does not specify a role scope. Azure roles in this design are assigned at resource-group scope (ADR-014).
2. **Problem:** How should the pipeline authenticate without creating a long-lived credential that can leak?
3. **Options considered:**
    - A) A service principal with a stored client secret.
    - B) Federated credentials (workload identity federation), one identity per environment.

    - C) Personal credentials of an administrator.
4. **Decision:** Option B. Each environment has its own deployment identity with a narrowly scoped role at that environment's resource group. The production identity is usable only from jobs that passed the approval gate and from `main`. Option C is rejected.
5. **Reasoning:** A federated credential removes the need to store and rotate a password, and tokens are short-lived and tied to a repository. Per-environment identities keep a compromise of the Development pipeline away from Production. Personal credentials break attribution and separation of accounts.
6. **Advantages:** No long-lived pipeline password; least privilege per environment; consistent with the access model.
7. **Disadvantages:** More setup and more identities; trust configuration must be scoped precisely; depends on the pipeline product supporting federation.
8. **Risks:** An over-broad trust rule that lets unintended workflows obtain tokens, or an over-broad role assignment. *Mitigation:* restrict trust to the specific repository, branch, or environment, assign roles at resource-group scope, review identities quarterly, and alert on role-assignment changes.
9. **Revisit when:** The pipeline product is chosen and lacks federation support, Production moves to its own subscription, or the deployment model changes.

> The exact role needed for deployment must be verified against the permissions of each candidate role before use. No identity has been created.

ADR-018 — Microsoft 365 recovery posture: built-in protections as baseline, dedicated backup product deferred until RPO and RTO exist

1. **Context:** Microsoft 365 data (Exchange mail, SharePoint, OneDrive) is not covered by Azure Backup (ADR-006). Microsoft documents built-in protections: Exchange Recoverable Items retention (14 days by default, up to 30), SharePoint and OneDrive recycle bins (93 days), file restore (30 days), version history, and short-term metadata backups. Microsoft also offers Microsoft 365 Backup as a pay-as-you-go service, and third-party products exist. RPO and RTO are not defined (A-06), and no prices are stated in this portfolio.
2. **Problem:** What recovery posture should the design assume for Microsoft 365 data, and when should a dedicated backup be chosen?
3. **Options considered:**
    - A) Built-in protections only, with gaps documented.
    - B) Microsoft 365 Backup (first-party, pay-as-you-go).
    - C) A third-party backup product.
4. **Decision:** Deferred. Option A is the documented baseline. The choice between B and C, or staying with A, is made only after management defines RPO, RTO, and retention for each data class and a restore test shows whether the built-in protections meet them.
5. **Reasoning:** Choosing a product before objectives exist would invent requirements and costs. Documenting the built-in limits keeps the gap visible and honest.
6. **Advantages:** No unjustified spend; the gaps are explicit; the decision is traceable to requirements.
7. **Disadvantages:** Recovery from long-undetected deletion, tenant-wide compromise, or retention beyond built-in windows may not be possible until the decision is made.
8. **Risks:** The deferral becomes permanent by neglect. *Mitigation:* the objectives table is reviewed yearly and after incidents, and restore tests are run per data owner.
9. **Revisit when:** Objectives are defined, a restore test fails, a contract or compliance driver sets retention, data volume or criticality grows, or Microsoft changes the built-in protections or the licence terms of its backup service.

> Feature behaviour and licence terms must be re-verified before use. No backup has been configured or tested.

ADR-019 — Proportionate change management (standard, normal, emergency) reusing pipeline approval, with a NIST-aligned incident lifecycle

1. **Context:** A small team already has pull-request review and a production approval gate (ADR-015, ADR-016). Changes outside code (tenant settings, firewall rules, roles) have no equivalent control. NIST SP 800-61 Rev. 3 states that organizations should use whichever incident life cycle model suits them best.
2. **Problem:** How should changes and incidents be governed without slowing a 15-person organization or duplicating controls?
3. **Options considered:**
    - A) Three change types (standard, normal, emergency) with approval by area, reusing existing gates, and a simple seven-step incident lifecycle.
    - B) Heavyweight change advisory board and formal ITIL-style process.
    - C) No formal process; ad-hoc communication.
4. **Decision:** Option A.
5. **Reasoning:** Option B is disproportionate at this size. Option C leaves risky changes (lockout, exposure) unreviewed and incidents unstructured. Option A adds review only where risk justifies it.
6. **Advantages:** Light; no double approval for releases; clear emergency path; consistent records; learning loop through reviews.
7. **Disadvantages:** Depends on discipline; the classification can be misjudged; a simple register offers little reporting.
8. **Risks:** Everything classed as standard or emergency to avoid review. *Mitigation:* when in doubt treat as normal, emergency changes are reviewed afterwards, and the mix of change types is tracked.
9. **Revisit when:** The team or system count grows, a compliance or customer requirement demands stricter evidence, or change-caused incidents rise.

> Time limits, lead times, response times, and notification duties are intentionally not defined.

ADR-020 — Small, owner-based alerting baseline; built-in network dashboards; no self-hosted monitoring tool

1. **Context:** Monitoring spans identity, Microsoft 365, the office network, Azure, applications, the pipeline, backups, secrets, and cost. Microsoft documents alert rules, action groups, stateful and stateless alerts, and 30-day storage of fired alerts. There are no on-premises servers (N-02). Thresholds and retention are not defined.
2. **Problem:** What monitoring baseline gives useful coverage without alert fatigue, extra cost, or a tool to host?
3. **Options considered:**
    - A) A small catalogue of owner-assigned alerts, routed to shared channels, plus built-in device dashboards for the network.
    - B) A cloud-managed network monitoring service from the device vendor.
    - C) A self-hosted monitoring platform.
    - D) Broad alerting on everything available.
4. **Decision:** Option A as baseline. Option B is an optional enhancement if available with the chosen devices and its licence and cost are verified. Options C and D are rejected for this scenario.
5. **Reasoning:** Alerts without an owner and a first action are noise. A self-hosted tool would need a server and maintenance the organization does not have. Built-in dashboards cost nothing extra and fit the size.
6. **Advantages:** Low cost and effort; clear ownership; links to runbooks and incident priorities.
7. **Disadvantages:** Limited correlation; manual review of network logs; gaps appear only after incidents reveal them.

8. **Risks:** Missed detection because the catalogue is small; alerts that silently stop working; short default log retention. *Mitigation:* add alerts after each incident, test notification routes, review alerts that never fire, and decide early which logs must outlive default retention.
9. **Revisit when:** Services or environments multiply, security needs call for central correlation, after-hours coverage is required, or compliance demands defined log retention.

> Entra log export paths and licence requirements are not verified. No alert has been created.

Technology Comparison and Decision Framework

> **Illustrative comparison for a fictional organization.** This document does **not** select an application hosting or database product. It exists because ADR-004 defers that decision until requirements are known. Facts about Azure services are taken from official Microsoft documentation **accessed 2026-11-13**; judgments are the author's and are labelled. No prices, sizes, or performance figures are given. Related: `architecture-decisions.md`, `../architecture/cloud-architecture.md`.

1. How to use this document

1. Gather the **inputs** in section 2 for the real application.
2. Use the **criteria** in section 3 to narrow the options.
3. Check the candidate against the **constraints** that the architecture already imposes (section 4).
4. Record the choice in a new ADR that supersedes the deferral in ADR-004.

Microsoft's own guidance states that its compute flowchart is "only a starting point": the candidate must still be evaluated against the real needs.

2. Inputs that are currently unknown (A-04)

Input	Why it changes the answer
Runtime and framework	Determines which hosting products can run it without rework
Application shape (web app, API, background jobs, event-driven, containerized)	Maps to different service types
Traffic pattern and peak load	Drives scaling needs and cost
Data model and volume	Drives the data product and backup approach
Team skills and size	A small team favors lower operational overhead
Availability and recovery needs (RPO/RTO)	Business requirement; not defined in this portfolio
Compliance or data-residency rules	May restrict regions or require isolation
Need for private network connectivity	Triggers a network design (ADR-005)

3. Hosting options

Characteristics below are from Microsoft's compute guidance unless marked as the author's judgment.

Option	Type	What Microsoft states	Fits when	Main trade-off (author's judgment where noted)
Azure Virtual Machines	IaaS	Most control, flexibility, and portability; you manage the VMs and networking; closest to on-premises	Full OS control or lift-and-shift is needed	Highest operational burden: patching, hardening, backup, and scaling are yours
Azure App Service	PaaS	Managed environment for web apps, back ends, and REST APIs; supports deployment slots	Standard web application or API with a small team	Less control over the host; fits only supported runtimes and patterns
Azure Container	Serverless containers	Built on Kubernetes and serverless, but does not expose	The application is containerized and	Requires a container build and registry practice

Option	Type	What Microsoft states	Fits when	Main trade-off (author's judgment where noted)
Apps		the underlying Kubernetes APIs	orchestration details are not needed	
Azure Functions	FaaS	Runs code triggered by events; Consumption and Flex Consumption plans are serverless	Event-driven or short-running work	Not a natural fit for long-running, stateful web workloads (author's judgment)
Azure Kubernetes Service	Managed Kubernetes	Direct access to the Kubernetes API and control plane	The team needs Kubernetes itself	High complexity for a 15-person organization; excluded by default (ADR-005)

Criteria Microsoft lists for comparison include team skills and operational overhead, networking, DevOps, scalability, multiregion options, security, TLS, cost, GPU support, and suitable architecture styles. All listed services are regional, so multiregion designs need an external router or load balancer.

Author's decision heuristic for this organization: start from the option with the **lowest operational overhead that runs the application correctly**, and move toward more control only when a specific requirement demands it. This follows the architecture principles of proportionality and avoiding overengineering. It is not a selection.

4. Constraints from the existing architecture

Whichever product is selected must:

#	Constraint	Source
1	Deploy one immutable artifact through Development, Staging, and Production	Overview; Phase 6
2	Use managed identities instead of stored credentials	Cloud architecture, section 7
3	Send logs and metrics to the shared monitoring workspace	Cloud architecture, section 9
4	Have a recoverable data design that can be restore-tested	ADR-006; cloud architecture, section 10
5	Run without a private network unless a trigger applies	ADR-005
6	Support the access model (resource-group-scoped roles, no standing production access)	ADR-014

5. Data tier options

The data tier is chosen **after** the data model is known. Microsoft's Azure Backup overview names these data services among supported workloads: SQL Server, SAP HANA, SAP ASE, PostgreSQL Server, PostgreSQL Flexible Server, MySQL Flexible Server, Azure Cosmos DB, Azure Files, Azure Blobs, and Azure Data Lake Storage.

Question	Why it matters
Is the data relational with transactions and joins, or document or key-value?	Selects the product family
Does the application already depend on a specific database engine or dialect?	Rework cost
Is a managed service available for that engine, or is self-hosting required?	Operational burden
How is the data protected and how is it restored?	Backup coverage must be confirmed in the support matrix for the exact product

Question	Why it matters
What are the recovery objectives?	Not defined here
How is access controlled and how are secrets handled?	Managed identity preferred; secrets in Key Vault

No data product is recommended here. Managed services are preferred by default over self-managed servers on virtual machines because they reduce patching and backup burden, but this is the author's judgment and each choice needs verification of feature and backup support.

6. Decision log summary (decisions already made)

For quick reference. Details and reasoning are in the ADRs.

Area	Chosen	Main alternative	Key trade-off	ADR
Subscription model	One subscription, resource group per environment	Subscription per environment	Low overhead versus stronger isolation	ADR-002
Identity source	Entra ID as the single source	Separate identity stores	One place for joiners and leavers versus per-system autonomy	ADR-003
MFA	Security defaults baseline	Conditional Access	No licence needed versus precise control	ADR-010
Devices	Documented manual baseline	Intune	No licence needed versus central enforcement	ADR-011
Administration	Separate admin accounts, emergency accounts	Daily accounts with admin roles	Safety versus convenience	ADR-012
Network segmentation	Three VLANs, firewall policy point	Flat network or many VLANs	Simplicity versus finer control	ADR-008
Staff Wi-Fi	Shared passphrase	802.1X	Simplicity versus per-user control	ADR-009
Remote access	No VPN by default	VPN for everything	Lower cost versus private connectivity	ADR-005
Hosting and database	**Deferred**	Pick now	Honesty versus a more concrete diagram	ADR-004
Microsoft 365 backup	Separate from Azure backup	One generic backup	Visible gaps versus less documentation	ADR-006
IaC	Concept only	Full templates	Honesty versus demonstrated syntax	ADR-007
Key Vault	One per environment	One shared vault	Strong boundary versus fewer objects	ADR-013
Azure roles	Group-based, resource-group scope, minimal subscription roles	Broad subscription roles	Isolation versus convenience	ADR-014
Branching	Short-lived branches, protected main	Branch per environment, GitFlow	Simplicity and build-once versus structure	ADR-015
Releases	One immutable artifact, approval before Production	Rebuild per environment, auto-deploy to Production	Safety versus speed	ADR-016
Pipeline identity	Federated credential per environment	Stored service-principal secret	No long-lived secret versus simpler setup	ADR-017
Microsoft 365 recovery	**Deferred**; built-in protections as baseline	Microsoft 365 Backup or third-party backup now	Honest gaps and no invented spend versus stronger recovery	ADR-018
Change and incident process	Three change types, reuse pipeline gates, simple lifecycle	Heavy CAB process, or none	Proportionate control versus formality	ADR-019

Area	Chosen	Main alternative	Key trade-off	ADR
Monitoring	Small owner-based alert set, built-in network dashboards	Self-hosted tool, vendor cloud service, broad alerting	Low cost and clarity versus correlation and coverage	ADR-020

7. Limitations

- No product has been tested or priced.
- Service characteristics may change; re-check Microsoft documentation before deciding.
- The heuristics are the author's and are not an official recommendation.

8. Sources

Accessed 2026-11-13.

Topic	Source
Compute service characteristics and criteria	Azure Architecture Center — Choose an Azure compute service
Data workloads that Azure Backup supports	Microsoft Learn — What is Azure Backup?

Interview Guide

> **Purpose:** help the author explain this portfolio honestly in an interview. It is a design portfolio, **not** evidence of deployment or production experience. Nothing in the repository has been built, tested, or operated. Every answer below should keep that distinction clear. Documents referenced are in this repository; decisions are in `../decisions/architecture-decisions.md`.

1. How to describe the project

Thirty-second version. "This is a documentation-first architecture portfolio for a fictional 15-person software company. I designed the identity, office network, Microsoft 365, Azure, DevOps, and operations layers on paper, recorded 20 decisions with trade-offs, and used official vendor documentation with access dates. I did not deploy anything, so I describe it as a design, not as experience."

Two-minute version.

1. *Why documentation-first.* I could not use paid cloud services or build a lab, and I did not want to present untested code as proven. Design reasoning, trade-offs, and operating processes are things I could demonstrate honestly.
2. *What it covers.* A reference scenario with explicit assumptions; a main architecture; an office network with three VLANs; identity and security; one Azure subscription with environment resource groups; a DevOps flow that promotes one artifact; and operations (backup, monitoring, incidents, change, governance).
3. *How decisions are recorded.* Each ADR has context, options, decision, reasoning, advantages, disadvantages, risks, and revisit conditions. Some decisions are deliberately **deferred** (hosting and database product, dedicated Microsoft 365 backup).
4. *What I would do next.* Validate the design in a real or trial environment, define recovery objectives with the business, and verify the licence-dependent features.

2. Honest framing

Question	Suggested answer
"Did you deploy this?"	No. It is a design. Nothing was built, tested, or validated, and the repository says so.
"Do you have production experience with this?"	This portfolio does not claim any. It shows how I reason about design, risk, and operations.
"Why are RPO and RTO missing?"	They must come from business requirements. Inventing numbers would be misleading, so the document gives the process for setting them.
"Why no prices?"	Prices and licence terms change; I would verify them at decision time and cite the source and date.
"Why is the hosting product undecided?"	The scenario does not contain the requirements that would decide it (ADR-004). The design stays valid for several products.
"What would you verify first?"	Licence-dependent features (Conditional Access, Intune, Entra log export), then recovery objectives and the Microsoft 365 backup decision.

3. Talking points by domain

3.1 Identity and security

- **Idea:** identity is the main security perimeter in a cloud-first company with no on-premises servers.
- **Key decisions:** Entra ID as single identity source (ADR-003); security defaults as the MFA baseline and Conditional Access as a licence-dependent option (ADR-010); separate admin accounts and two emergency access accounts (ADR-012).
- **Trade-offs:** security defaults are simple and free but less flexible than Conditional Access; separate admin accounts add friction but limit damage from a stolen daily account.
- **Be ready to explain:** the difference between Entra roles, Microsoft 365 roles, and Azure RBAC, which are separate permission systems.
- **Be careful:** do not assume Conditional Access, PIM, or Intune are available; the documents mark them as licence-dependent or unverified.

3.2 Office network

- **Idea:** three VLANs (Staff, Guest, Management) with the firewall as the single policy point (ADR-008).
- **Trade-offs:** simple and understandable versus finer segmentation; shared-passphrase Wi-Fi is easy but weaker than 802.1X, which is documented as the upgrade path (ADR-009); no VPN by default (ADR-005).
- **Be ready to explain:** why VLANs alone are not security, and why guest isolation needs firewall rules.

3.3 Azure

- **Idea:** one subscription with a resource group per environment plus a shared operations group (ADR-002).
- **Trade-offs:** resource groups give logical separation, not full isolation; a separate subscription for Production is a documented growth path.
- **Key decisions:** one Key Vault per environment with managed identities (ADR-013); group-based roles at resource-group scope (ADR-014).
- **Be ready to explain:** budgets alert but do not stop spending; tagging is my own recommendation.

3.4 DevOps

- **Idea:** short-lived branches into a protected main (ADR-015); build once, promote one artifact through Development and Staging to Production with approval by someone other than the requester (ADR-016); federated deployment identity instead of stored secrets (ADR-017).
- **Trade-offs:** approval gates slow releases but add a human check; rollback by redeploying the previous artifact works with any product, while slot swap is product-specific.
- **Be careful:** Bicep appears only as a concept (ADR-007). No template was run, so none is presented as working.

3.5 Operations

- **Backup and recovery:** a backup is proven only by a successful restore. Azure Backup does not cover Microsoft 365 data (ADR-006), and the dedicated Microsoft 365 backup choice is deferred until objectives exist (ADR-018).
- **Monitoring:** a small catalogue of alerts, each with an owner, route, and first action; no thresholds invented (ADR-020).
- **Incidents and change:** a simple lifecycle aligned with NIST SP 800-61 Rev. 3, three change types that reuse existing approval gates (ADR-019).
- **Governance:** ownership with backups, resource lifecycle, a cost review routine, and a runbook standard.

4. Likely questions and short answers

Question	Short answer
Why Entra ID security defaults rather than Conditional Access?	They are free and need no design effort. Conditional Access gives control but depends on licensing, which I did not assume (ADR-010).

Question	Short answer
What is the biggest risk in your design?	Compromise of an administrative account. Controls are separate admin accounts, emergency accounts, restricted subscription roles, alerts on role changes, and regular role reviews.
How would you handle a leaked secret?	Rotate immediately, check usage logs, fix the process gap, and add secret detection (incident response, section 7.2).
What happens if a release breaks Production?	Decide rollback or roll forward, redeploy the previous artifact, verify, communicate, and open a problem record if the cause is unclear.
How do you recover a deleted SharePoint file?	Recycle bin first (93 days documented); Files Restore for bulk changes (30 days). Beyond that, built-in protections end, which is why the backup decision exists.
How would the design grow?	Each document has a growth-path table: more VLANs or 802.1X, a separate Production subscription, Conditional Access and Intune, on-call and central monitoring.
What would you do differently with a budget?	Build a trial environment to test the design, then replace "proposed" with "implemented" only where I verified it.

5. Trade-off summary

The one-page comparison of every decision is in `../decisions/technology-comparison.md`, section 6. Use it to answer "why this and not that".

6. Statements to avoid

- "I built" or "I deployed" anything from this repository.
- Any claim about performance, uptime, cost, or recovery time. No such numbers exist here.
- Treating a licence-dependent feature as available.
- Describing the design as the only correct one. It is a reasoned proposal for stated assumptions.